



BỘ GIÁO DỤC VÀ ĐÀO TẠO
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ TP. HCM

ĐỒ ÁN CHUYÊN NGÀNH AN NINH MẠNG

PHÁT HIỆN TẤN CÔNG MẠNG BẰNG WAZUH + ELK STACK

Giảng viên hướng dẫn: ThS. Phan Đình Duy Thông

Sinh viên thực hiện	Lớp	MSSV
1. Nguyễn Tài Trung	22DTHE6	2280618942
2. Trần Duy Thế	22DTHC3	2280603020

TP. Hồ Chí Minh, 2025

LỜI MỞ ĐẦU

Trong kỷ nguyên chuyển đổi số mạnh mẽ hiện nay, an toàn thông tin đã trở thành một yếu tố sống còn đối với mọi tổ chức và doanh nghiệp. Sự gia tăng cả về số lượng lẫn mức độ tinh vi của các cuộc tấn công mạng như mã độc tống tiền (Ransomware), lừa đảo (Phishing), và tấn công từ chối dịch vụ (DDoS) đã đặt ra những thách thức nghiêm trọng về việc bảo vệ dữ liệu và duy trì hoạt động kinh doanh liên tục. Việc chỉ dựa vào các biện pháp phòng thủ truyền thống như tường lửa hay phần mềm diệt virus đã không còn đủ.

Để đối phó hiệu quả, các tổ chức cần một hệ thống giám sát và phát hiện xâm nhập (SIEM/IDS) mạnh mẽ, có khả năng thu thập, phân tích lượng lớn dữ liệu nhật ký (log) và sự kiện bảo mật theo thời gian thực để nhanh chóng nhận diện các hành vi bất thường và dấu hiệu tấn công.

Wazuh, một nền tảng SIEM mã nguồn mở hàng đầu, tích hợp các khả năng của Hệ thống Phát hiện Xâm nhập dựa trên Host (HIDS), đánh giá lỗ hổng, kiểm soát cấu hình và giám sát tuân thủ. Khi kết hợp với ELK Stack (Elasticsearch, Logstash, Kibana) – bộ công cụ mạnh mẽ cho việc thu thập, lưu trữ, phân tích và trực quan hóa dữ liệu, Wazuh+ELK tạo nên một giải pháp toàn diện. Hệ thống này không chỉ giúp phát hiện các mối đe dọa mà còn cung cấp bức tranh toàn cảnh về tình trạng an ninh của hệ thống, hỗ trợ công tác điều tra sự cố và ứng phó kịp thời.

Với tầm quan trọng cấp thiết đó, nhóm chúng tôi quyết định lựa chọn đề tài: "Xây dựng và Triển khai Hệ thống Phát hiện Tấn công Mạng bằng Wazuh và ELK Stack". Mục tiêu của đề tài là nghiên cứu chuyên sâu về kiến trúc, cơ chế hoạt động, cũng như xây dựng thành công một mô hình thực tế, đáp ứng được yêu cầu giám sát và phát hiện các kiểu tấn công mạng phổ biến, góp phần nâng cao năng lực bảo vệ an ninh mạng.

Chúng tôi tin rằng việc làm chủ công nghệ này sẽ là cơ hội quý giá để các thành viên trong nhóm trang bị thêm kiến thức thực tiễn và kỹ năng triển khai hệ thống bảo mật hiện đại.

LỜI CẢM ƠN

Để hoàn thành đề tài "Xây dựng và Triển khai Hệ thống Phát hiện Tấn công Mạng bằng Wazuh và ELK Stack", chúng em đã nhận được sự hỗ trợ và giúp đỡ to lớn từ nhiều cá nhân và tổ chức.

Trước hết, chúng em xin bày tỏ lòng biết ơn sâu sắc và lời tri ân chân thành nhất đến **ThS. Phan Đình Duy Thông**. Thầy không chỉ là người định hướng nghiên cứu, mà còn là người trực tiếp hướng dẫn chúng em từ những bước đi đầu tiên trong việc tìm hiểu, triển khai Wazuh và tích hợp ELK Stack. Những kiến thức chuyên sâu, sự tận tâm và những góp ý kịp thời của Thầy chính là yếu tố then chốt giúp chúng em vượt qua mọi khó khăn kỹ thuật và hoàn thiện đề tài này.

Chúng em xin gửi lời cảm ơn đến Quý Thầy/Cô thuộc Khoa/Bộ môn đã trang bị cho chúng em nền tảng kiến thức vững chắc về An toàn Thông tin và Công nghệ Mạng, tạo tiền đề để chúng em có thể tiếp cận và thực hiện một đề tài có tính ứng dụng cao như hệ thống SIEM mã nguồn mở.

Cuối cùng, xin cảm ơn các thành viên trong nhóm đã luôn đoàn kết, làm việc nhiệt tình và chia sẻ kiến thức, kinh nghiệm để cùng nhau đạt được mục tiêu chung của đồ án.

Dù đã nỗ lực hết mình, do giới hạn về thời gian và kinh nghiệm thực tế trong lĩnh vực an ninh mạng phức tạp, đề tài chắc chắn vẫn còn những thiếu sót. Kính mong Thầy **Phan Đình Duy Thông** và Quý Thầy/Cô thông cảm, và góp ý quý báu để đề tài của chúng em được hoàn thiện hơn nữa.

Chúng em xin chân thành cảm ơn!

Sinh viên thực hiện

Nguyễn Tài Trung

Trần Duy Thế

NHIỆM VỤ ĐỒ ÁN

1. Mục tiêu của Demo

Mục tiêu của Demo là xây dựng mô hình phòng thí nghiệm (Lab) an toàn thông tin trên nền tảng ảo hóa, triển khai giải pháp giám sát an ninh mạng tích hợp giữa Wazuh và ELK Stack (sử dụng kiến trúc tinh gọn Direct Ingest).

Demo tập trung vào việc thực hiện các kịch bản tấn công mạng phổ biến nhằm vào máy chủ Linux và Web Server, qua đó đo lường hiệu quả phát hiện của hệ thống thông qua các chỉ số định lượng cụ thể (Precision, Recall, Latency). Đồng thời, Demo thể hiện trọn vẹn quy trình khép kín: Tấn công - phát hiện - cảnh báo - phản ứng tự động (SOAR/AI), nhằm chứng minh tính khả thi, độ chính xác và khả năng ứng dụng của giải pháp trong việc bảo vệ hệ thống thông tin.

2. Phạm vi và kiến trúc triển khai

Hệ thống demo được triển khai tinh gọn gồm 3 máy ảo (VM) cài đặt trên cùng một máy chủ vật lý (Host), sử dụng kiến trúc chuyên tiếp log trực tiếp (Direct Ingest) và tích hợp giám sát mạng chuyên sâu:

- VM1 (SIEM Server): Đóng vai trò là trung tâm dữ liệu, cài đặt Elasticsearch để lưu trữ, đánh chỉ mục log và Kibana để trực quan hóa, hiển thị Dashboard an ninh mạng.
- VM2 (Wazuh Manager): Máy chủ quản lý bảo mật trung tâm. Ngoài Wazuh Manager, máy này cài đặt Filebeat để đẩy trực tiếp các cảnh báo (Alerts) sang Elasticsearch.
- VM3 (Web/Agent): Đóng vai trò là máy mục tiêu (Victim). Tại đây tích hợp nhiều lớp bảo vệ: Toàn bộ các thành phần này được kết nối trong mạng nội bộ (NAT Network hoặc Host-Only) để đảm bảo tính bảo mật và ổn định.
 - **Nginx:** Web Server (đối tượng được bảo vệ).
 - **Suricata:** Hệ thống phát hiện xâm nhập (NIDS) để bắt các gói tin tấn công mạng độc hại.
 - **Wazuh Agent:** Thu thập log hệ thống và log từ Suricata gửi về Manager.
 - **Filebeat:** Thu thập log truy cập Web gửi về Elasticsearch.

Luồng dữ liệu được thống nhất theo quy trình sau:

Tấn công mạng → Suricata phát hiện (ghi log JSON) → Wazuh Agent đọc log → Wazuh Manager (Alert) → Elasticsearch.

3. Nhiệm vụ cụ thể trong Demo

1. Xây dựng môi trường SIEM hoàn chỉnh tích hợp Wazuh, Suricata và ELK Stack
2. Triển khai và cấu hình IDS Suricata trên máy chủ Web để giám sát lưu lượng mạng và phát hiện các tấn công
3. Thực hiện và ghi nhận kết quả của 05 kịch bản tấn công trên nền tảng Linux/Web: SSH brute-force, SQL Injection (SQLi), Cross-Site Scripting (XSS), Local File Inclusion (LFI) và File Integrity Monitoring (FIM).
4. Cấu hình phát hiện và cảnh báo tự động dựa trên Ruleset của Wazuh; thiết lập kênh cảnh báo qua Email.
5. Phân tích và đánh giá hiệu quả phát hiện của hệ thống thông qua các chỉ số định lượng: Precision, Recall, F1-Score, FPR và Latency (độ trễ cảnh báo).
6. Triển khai cơ chế Phản ứng tự động (Wazuh Active Response) để ngăn chặn mối đe dọa ngay lập tức (ví dụ: Tự động chặn IP khi phát hiện Brute-force).
7. Triển khai SOAR mini hoặc AI/ML nâng cao.

8. Xây dựng Dashboard trên Kibana để trực quan hóa dữ liệu tấn công và thực hiện quay video demo quy trình hoạt động.

9. Đánh giá tổng thể, tổng hợp số liệu, đóng gói tài liệu kỹ thuật và hoàn thiện báo cáo đề án.

4. Kết quả mong đợi

- Hệ thống Wazuh + ELK Stack hoạt động ổn định, phát hiện chính xác các hành vi tấn công.

- Các chỉ số đạt chuẩn: Latency $\leq 10s$ (FIM $\leq 5s$), Precision ≥ 0.90 , Recall ≥ 0.85 , F1 ≥ 0.87 , FPR $\leq 5\%$.

[illegible]

MỤC LỤC

LỜI MỞ ĐẦU	i
LỜI CẢM ƠN	ii
NHIỆM VỤ ĐỒ ÁN	iii
NHẬN XÉT CỦA GIẢNG VIÊN	v
MỤC LỤC	vi
DANH MỤC HÌNH ẢNH	vii
CHƯƠNG 1: TỔNG QUAN.....	1
1.1. Tổng quan về vấn đề được nghiên cứu	1
1.2. Khảo sát thực trạng	1
1.3. Đánh giá.....	1
1.3.1. Ưu điểm	1
1.3.2. Nhược điểm.....	2
1.4. Nhiệm vụ của đồ án.....	2
1.5. Đối tượng và phạm vi nghiên cứu.....	2
1.6. Cấu trúc đồ án	3
CHƯƠNG 2: CƠ SỞ LÝ THUYẾT.....	4
2.1. Tổng quan về hệ thống phát hiện và quản lý sự kiện an ninh (SIEM)	4
2.1.1. Khái niệm.....	4
2.1.2. Vai trò	4
2.2.3. Ưu điểm của kiến trúc Direct Ingest	5
2.3. Giới thiệu về Wazuh.....	5
2.3.1. Tổng quan	5
2.3.2. Kiến trúc hệ thống Wazuh	5
2.3.3. Các tính năng chính	5
2.4. Các công cụ hỗ trợ trong mô hình.....	6
2.4.2. Suricata (IDS)	6
2.4.3. Filebeat	6
2.5. Các kỹ thuật phát hiện tấn công mạng	6
2.5.1. SSH Brute-Force	6
2.5.2. SQL Injection (SQLi)	6
2.5.3. Cross-Site Scripting (XSS)	6
2.5.4. Local File Inclusion (LFI)	7
2.5.5. File Integrity Monitoring (FIM).....	7
2.6. Các chỉ số đánh giá hiệu quả phát hiện	7
2.7. Tích hợp nâng cao (SOAR / AI/ML)	8

2.7.1. SOAR mini.....	8
2.7.2. AI/ML	8
2.8. Kết luận chương	8
CHƯƠNG 3: THIẾT KẾ HỆ THỐNG VÀ KẾT QUẢ THỰC NGHIỆM	9
3.1. Giới thiệu chương	9
3.3. Cài Elasticsearch	11
3.4. Cài Kibana	12
3.5. Cài Wazuh Manager	14
3.6. Filebeat trên VM2	16
3.7. Cài đặt Wazuh Agent	17
3.8. Cài đặt Suricata IDS	19
3.9. Cài Nginx + Filebeat trên VM3	20
3.10. Tạo Data View Kibana	22
3.11. SSH Brute-force	23
3.12. FIM – File Integrity Monitoring	25
3.13. SQLi / XSS / LFI	27
3.14. Watcher Email Alert.....	36
3.15. Kiểm tra độ trễ (Latency)	38
CHƯƠNG 4: KẾT LUẬN THỰC NGHIỆM	48
CHƯƠNG 5: KẾT LUẬN, HẠN CHẾ, HƯỚNG PHÁT TRIỂN TRONG TƯƠNG LAI	50
5.1. Kết luận.....	50
5.2. Hạn chế.....	50
5.3. Kiến nghị và hướng phát triển trong tương lai	51
TÀI LIỆU THAM KHẢO.....	52

DANH MỤC HÌNH ẢNH

Hình 1: Hình ảnh mô hình hoạt động	9
Hình 2: Ping thành công từ SIEM tới WAZUH,WEB	10
Hình 3: Ping thành công từ wazuh đến siem và web	11
Hình 4: Ping thành công từ web đến siem và wazuh	11
Hình 5: Hình ảnh Elasticsearch hoạt động.....	12
Hình 6: Hình ảnh kibana hoạt động.....	13
Hình 7: Giao diện đăng nhập Kibana	14
Hình 8: Hình ảnh Manager hoạt động	15
Hình 9: Trạng thái Manager hiển thị trong Dashboard	16

Hình 10: Giao diện filebeat trên VM2 hoạt động	16
Hình 11: Index wazuh-alerts-* xuất hiện trong Elasticsearch	17
Hình 12: Agent hoạt động trên VM3.....	18
Hình 13: Agent hiển thị Active trong Wazuh Dashboard	18
Hình 14: Suricata signatures hoạt động.....	19
Hình 15: Suricata signatures hiển thị trong Kibana	20
Hình 16: Log Nginx hoạt động trên VM3	21
Hình 17: Log Nginx hiển thị trong Kibana Discover	22
Hình 18: Giao diện Data View filebeat-*	22
Hình 19: Giao diện View wazuh-alerts-*	23
Hình 20: Cảnh báo SSH Failed trên Kibana.	23
Hình 21: Cảnh báo SSH Failed Attempts trên Wazuh.	24
Hình 22: Tấn công Brute-Force.....	24
Hình 23: Hình ảnh dashboard cảnh báo.....	25
Hình 24: Hình ảnh thay đổi file kích hoạt FIM.....	26
Hình 25: Giao diện cảnh báo Kibana.....	26
Hình 26: Giao diện cảnh báo Wazuh.....	27
Hình 27: Hình ảnh chạy lệnh tấn công SQL Injection.	28
Hình 28: Hình ảnh chạy lệnh tấn công Cross-Site Scripting (XSS).	28
Hình 29: Hình ảnh chạy lệnh tấn công Local File Inclusion (LFI).....	29
Hình 30: Hình ảnh chạy lệnh kiểm tra real-time 3 tấn công.....	29
Hình 31: Hình ảnh Wazuh Agent trên VM3 sẽ gửi log Suricata đến Manager.....	30
Hình 32: Hình ảnh cảnh báo tấn công trên Wazuh.	30
Hình 33: Hình ảnh cảnh báo tấn công trên Kibana.	31
Hình 34: Hình ảnh Biểu đồ số lượng cảnh báo theo thời gian.....	31
Hình 35: Hình ảnh Các chữ ký Suricata được kích hoạt nhiều nhất.....	32
Hình 36: Hình ảnh Các địa chỉ IP tấn công nhiều nhất	32
Hình 37: Hình ảnh Các địa chỉ IP mục tiêu bị tấn công.....	33
Hình 38: Hình ảnh Biểu đồ cảnh báo theo từng agent	33
Hình 39: Hình ảnh Biểu đồ so sánh số lượng cảnh báo theo từng endpoint	34
Hình 40: Hình ảnh Biểu đồ người dùng tạo nhiều sự kiện xác thực nhất	34
Hình 41: Hình ảnh Số lượng sự kiện thay đổi tệp tin (FIM)	35
Hình 42: Hình ảnh Các tệp tin thay đổi nhiều nhất.....	35
Hình 43: Hình ảnh Các chiến thuật MITRE ATT&CK được kích hoạt	36
Hình 44: Hình ảnh Bảng chi tiết alert theo endpoint.....	36
Hình 45: Cài đặt và cấu hình Email Alert gửi từ Watcher trên Dev Tools.	37
Hình 46: Hình ảnh Email Alert gửi từ Watcher.	37
Hình 47: Hình ảnh Chi tiết log được hiển thị trong email.....	38
Hình 48: Hình ảnh phát hiện tấn công brute-force.....	38
Hình 49: Hình ảnh Log kiểm tra Latency qua curl.	39
Hình 50: Dataset raw sau khi làm sạch và gán nhãn.....	40
Hình 51: Các chỉ số wazuh_metrics đã được tính toán và đánh giá	41
Hình 52: Confusion Matrix của Random Forest	41
Hình 53: Precision/Recall của Random Forest	42
Hình 54: Confusion Matrix của XGBoost	43
Hình 55: Precision/Recall của XGBoost	44
Hình 56: Confusion Matrix của CatBoost	45
Hình 57: Precision/Recall CatBoost.....	46

Hình 58: Biểu đồ so sánh Precision/Recall của 3 mô hình.....	47
Hình 59: Biểu đồ tổng hợp F1-score và FPR.....	47

CHƯƠNG 1: TỔNG QUAN

1.1. Tổng quan về vấn đề được nghiên cứu

- Trong bối cảnh kỷ nguyên số, các cuộc tấn công mạng đang gia tăng chóng mặt cả về số lượng, quy mô lẫn mức độ tinh vi. Các kỹ thuật tấn công như Brute-force, khai thác lỗ hổng Web (SQLi, XSS) hay thay đổi tệp tin hệ thống trái phép ngày càng trở nên khó lường. Do đó, việc phát hiện sớm và phản ứng nhanh với các hành vi xâm nhập đã trở thành yêu cầu cấp thiết đối với mọi tổ chức, doanh nghiệp và cơ quan quản lý hệ thống thông tin.
- Thực tế cho thấy, các giải pháp an ninh mạng truyền thống chỉ dừng lại ở việc ghi nhận và lưu trữ nhật ký (log) là chưa đủ. Hệ thống phòng thủ hiện đại cần phải có khả năng tập trung hóa dữ liệu, phân tích chuyên sâu, đưa ra cảnh báo chính xác và quan trọng nhất là khả năng tự động phản ứng trước các mối đe dọa ngay khi chúng vừa xuất hiện.
- Xuất phát từ nhu cầu đó, đề án “Phát hiện tấn công mạng sử dụng Wazuh kết hợp ELK Stack” được thực hiện với mục tiêu xây dựng một mô hình SIEM (Security Information and Event Management) hoàn chỉnh trên nền tảng ảo hóa. Điểm nổi bật của đề tài là việc triển khai hệ thống theo kiến trúc Direct Ingest (thu thập trực tiếp), giúp tối ưu hóa tài nguyên phần cứng nhưng vẫn đảm bảo khả năng giám sát log thời gian thực, phát hiện bất thường và tích hợp cơ chế Active Response (Phản ứng tự động) để ngăn chặn mối đe dọa tức thì.

1.2. Khảo sát thực trạng

- Hiện nay, đa số các tổ chức tại Việt Nam vẫn đối mặt với thách thức trong quản lý an ninh mạng do sử dụng các công cụ giám sát rời rạc, thiếu tính đồng bộ. Dữ liệu nhật ký (log) từ các máy chủ, thiết bị mạng hoặc ứng dụng thường được lưu trữ phân tán, gây khó khăn lớn cho việc tổng hợp và phân tích chuỗi sự kiện. Điều này dẫn đến độ trễ cao trong việc phát hiện tấn công, tỷ lệ cảnh báo sai (False Positive) lớn và khó đánh giá được toàn diện tình trạng an ninh của hệ thống.
- Mặc dù các nền tảng SIEM thương mại như Splunk, IBM QRadar hay ArcSight rất mạnh mẽ, nhưng chi phí bản quyền đắt đỏ là rào cản lớn đối với nhiều đơn vị. Trước thực tế đó, sự kết hợp giữa Wazuh (nền tảng bảo mật mã nguồn mở phát triển từ OSSEC) và Elasticsearch – Kibana nổi lên như một giải pháp thay thế hiệu quả. Mô hình này không chỉ miễn phí, linh hoạt mà còn cho phép triển khai kiến trúc thu thập log trực tiếp (Direct Ingest), giúp giảm tải tài nguyên xử lý trung gian, đặc biệt phù hợp cho mục tiêu nghiên cứu và triển khai tại các môi trường thử nghiệm có cấu hình hạn chế.
- Thông qua việc triển khai mô hình này, nhóm nghiên cứu mong muốn chứng minh khả năng phát hiện tấn công theo thời gian thực (Real-time detection) của giải pháp mã nguồn mở. Đồng thời, đề án giúp sinh viên nắm vững quy trình kỹ thuật từ việc thu thập, chuẩn hóa log đến việc xây dựng các Dashboard giám sát an ninh mạng chuyên nghiệp phục vụ công tác điều tra và phản ứng sự cố.

1.3. Đánh giá

1.3.1. Ưu điểm

- **Chi phí thấp và linh hoạt:** Mô hình sử dụng hoàn toàn công nghệ mã nguồn mở (Wazuh, Elasticsearch, Kibana), giúp loại bỏ chi phí bản quyền phần mềm, đồng thời cho phép tùy biến cao mã nguồn để phù hợp với nhu cầu giám sát cụ thể.

- **Kiến trúc tối ưu (Direct Ingest):** Việc loại bỏ Logstash và sử dụng Filebeat đẩy log trực tiếp giúp hệ thống giảm bớt độ trễ (Latency), tiết kiệm tài nguyên tính toán cho máy chủ SIEM, phù hợp với các môi trường tài nguyên hạn chế.
- **Khả năng giám sát toàn diện:** Cung cấp khả năng phân tích tập trung, giám sát thời gian thực và cảnh báo tự động ngay khi phát hiện dấu hiệu tấn công.
- **Khả năng mở rộng:** Hệ thống hỗ trợ đa nền tảng (Linux, Windows, macOS). Dù đồ án tập trung vào Linux, nhưng trong thực tế doanh nghiệp có thể dễ dàng mở rộng Agent sang các máy trạm Windows mà không cần thay đổi kiến trúc lõi.
- **Tùy biến chuyên sâu:** Cho phép người quản trị tự định nghĩa các luật (Rules), bộ giải mã (Decoders) và giao diện (Dashboard) để bám sát các kịch bản tấn công thực tế.

1.3.2. Nhược điểm

- **Yêu cầu tài nguyên phần cứng:** Mặc dù đã tối ưu hóa, thành phần Elasticsearch vẫn yêu cầu lượng RAM tương đối lớn để duy trì hiệu năng đánh chỉ mục và tìm kiếm nhanh trên môi trường ảo hóa.
- **Độ phức tạp trong tinh chỉnh:** Việc thiết lập các ngưỡng cảnh báo để cân bằng các chỉ số hiệu quả (Precision, Recall, F1) và giảm thiểu tỷ lệ cảnh báo sai (FPR) đòi hỏi nhiều thời gian kiểm thử và kinh nghiệm thực tế.
- **Thách thức trong cấu hình tích hợp:** Việc cấu hình kết nối bảo mật (SSL/TLS) trực tiếp giữa Filebeat và Elasticsearch phức tạp hơn so với mô hình qua Logstash truyền thống, dễ phát sinh lỗi xác thực chứng chỉ trong quá trình triển khai ban đầu.

1.4. Nhiệm vụ của đồ án

1. **Xây dựng cơ sở hạ tầng:** Thiết lập môi trường Lab an ninh mạng gồm: Wazuh Manager, Elasticsearch, Kibana và các tác nhân giám sát (Wazuh Agent, Filebeat, Suricata IDS).
2. **Triển khai kịch bản tấn công:** Thực hiện 05 kịch bản tấn công tiêu biểu (SSH Brute-force, SQLi, XSS, LFI, FIM) và kiểm chứng khả năng phát hiện đa lớp:
 - SSH Brute-force (Tấn công dò mật khẩu SSH).
 - SQL Injection (SQLi - Tiêm nhiễm mã độc SQL).
 - Cross-Site Scripting (XSS - Chèn mã độc JavaScript).
 - Local File Inclusion (LFI - Chèn tệp tin cục bộ).
 - File Integrity Monitoring (FIM - Giám sát thay đổi tệp tin trái phép).
3. **Cấu hình phát hiện và cảnh báo:** Viết và tinh chỉnh các luật (Rules) trên Wazuh để nhận diện chính xác hành vi tấn công, đồng thời cấu hình cơ chế gửi cảnh báo tự động qua Email hoặc hiển thị trên Dashboard Kibana.
4. **Đánh giá hiệu quả hệ thống:** Đo lường và phân tích các chỉ số định lượng bao gồm: Độ chính xác (Precision), Độ bao phủ (Recall), Điểm F1 (F1-Score), Tỷ lệ cảnh báo sai (FPR) và Độ trễ (Latency).
5. **Triển khai phản ứng tự động (Nâng cao):** Tích hợp cơ chế Active Response (SOAR mini) của Wazuh để tự động ngăn chặn nguồn tấn công (ví dụ: chặn địa chỉ IP qua tường lửa) khi phát hiện hành vi Brute-force.
6. **Hoàn thiện sản phẩm:** Xây dựng Dashboard phân tích an ninh trực quan, thực hiện video demo minh họa quy trình hoạt động và hoàn thiện báo cáo tổng kết đồ án.

1.5. Đối tượng và phạm vi nghiên cứu

- Đối tượng nghiên cứu:
 - Các hệ thống máy chủ chạy hệ điều hành Linux (Ubuntu Server).
 - Các dịch vụ Web Server (như Nginx) và các tệp tin cấu hình hệ thống quan trọng cần được bảo vệ.
 - Các hành vi tấn công mạng phổ biến và dấu hiệu nhận biết (Signature/Behavior) của chúng trong nhật ký hệ thống (Log).
- Phạm vi nghiên cứu:
 - **Về không gian:** Giới hạn trong môi trường thử nghiệm ảo hóa (Lab), các máy ảo được kết nối trong mạng nội bộ (Host-Only/NAT).
 - **Về kiến trúc:** Tập trung vào mô hình thu thập log trực tiếp (Direct Ingest) từ Agent/Filebeat về Elasticsearch, không nghiên cứu sâu về kiến trúc Logstash phân tán phức tạp.
 - **Về hoạt động:** Chỉ thực hiện mô phỏng tấn công trong môi trường Lab an toàn, tuyệt đối không thực hiện tấn công ra mạng Internet. Đề án tập trung vào khía cạnh tấn công, giám sát, phát hiện và cảnh báo nhanh, không đi sâu vào quy trình điều tra số (Digital Forensics) hậu sự cố.

1.6. Cấu trúc đề án

- Chương 1: TỔNG QUAN.
- Chương 2: CƠ SỞ LÝ THUYẾT.
- Chương 3: THIẾT KẾ HỆ THỐNG VÀ KẾT QUẢ THỰC NGHIỆM.
- Chương 4: KẾT LUẬN THỰC NGHIỆM.
- Chương 5: KẾT LUẬN, HẠN CHẾ, HƯỚNG PHÁT TRIỂN TRONG TƯƠNG LAI.

CHƯƠNG 2: CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về hệ thống phát hiện và quản lý sự kiện an ninh (SIEM)

2.1.1. Khái niệm

SIEM (Security Information and Event Management) là giải pháp quản lý thông tin và sự kiện an ninh tập trung, cung cấp cái nhìn toàn diện về trạng thái bảo mật của hệ thống CNTT. Một hệ thống SIEM tiêu chuẩn có các khả năng cốt lõi sau: Thu thập log từ nhiều nguồn (máy chủ, ứng dụng, thiết bị mạng, firewall, IDS/IPS...);

- **Thu thập dữ liệu (Data Collection):** Tiếp nhận nhật ký (log) từ nhiều nguồn khác nhau như máy chủ, thiết bị mạng, tường lửa (Firewall), hệ thống phát hiện xâm nhập (IDS/IPS) và các ứng dụng.
- **Chuẩn hóa và lưu trữ:** Chuyển đổi dữ liệu thô từ các định dạng khác nhau về một định dạng chuẩn (như JSON, ECS) và lưu trữ tập trung để phục vụ truy vấn.
- **Phân tích và phát hiện (Analysis & Detection):** Sử dụng các luật (rules) và thuật toán tương quan (correlation) để phát hiện các hành vi bất thường hoặc dấu hiệu tấn công tiềm ẩn.
- **Cảnh báo và báo cáo:** Gửi cảnh báo tức thì đến người quản trị và xuất các báo cáo tuân thủ theo thời gian thực.

Về mặt kiến trúc, SIEM kết hợp hai thành phần chính:

- **SIM (Security Information Management):** Tập trung vào việc lưu trữ lâu dài, phân tích dữ liệu lịch sử và báo cáo xu hướng..

SEM (Security Event Management): Tập trung vào việc giám sát thời gian thực, tương quan sự kiện và phản ứng nhanh với sự cố.

2.1.2. Vai trò

Trong mô hình bảo mật hiện đại, SIEM đóng vai trò trung tâm giúp tổ chức:

- **Phát hiện sớm các mối đe dọa:** Nhận diện các cuộc tấn công phức tạp mà các giải pháp đơn lẻ (như Antivirus, Firewall) có thể bỏ sót.
- **Giảm thời gian phản ứng (MTTR):** Cung cấp thông tin chi tiết và ngữ cảnh của sự cố, giúp đội ngũ bảo mật xử lý nhanh chóng.
- **Hỗ trợ điều tra số (Forensics):** Lưu trữ log tập trung giúp truy vết nguồn gốc và diễn biến của cuộc tấn công sau khi sự cố xảy ra.
- **Đảm bảo tuân thủ (Compliance):** Đáp ứng các tiêu chuẩn bảo mật quốc tế (như PCI DSS, ISO 27001) thông qua hệ thống báo cáo tự động.

2.2. Giới thiệu về ELK Stack (Mô hình Direct Ingest)

2.2.1. Khái niệm

ELK Stack (hay Elastic Stack) là bộ công cụ mã nguồn mở mạnh mẽ để thu thập, tìm kiếm, phân tích và trực quan hóa dữ liệu log theo thời gian thực. Trong phạm vi đề án này, để tối ưu hóa tài nguyên và giảm độ trễ, nhóm nghiên cứu triển khai mô hình Direct Ingest (Thu thập trực tiếp), lược bỏ thành phần Logstash và sử dụng Filebeat làm nòng cốt chuyển dữ liệu.

2.2.2. Các thành phần chính trong mô hình

Mô hình triển khai bao gồm 03 thành phần chính:

1. Elasticsearch:

- Là trái tim của hệ thống, đóng vai trò là cơ sở dữ liệu NoSQL dạng văn bản.

- Chịu trách nhiệm lưu trữ, đánh chỉ mục (indexing) và tìm kiếm dữ liệu log phân tán với tốc độ cao.

2. Kibana:

- Là giao diện người dùng (GUI) làm việc trực tiếp với Elasticsearch.
- Cho phép người quản trị trực quan hóa dữ liệu dưới dạng biểu đồ, bản đồ, tạo Dashboard giám sát và quản lý các cảnh báo an ninh.

3. Filebeat

- Là một agent nhẹ (lightweight shipper) được cài đặt trên các máy trạm (Client) hoặc máy chủ quản lý.
- Nhiệm vụ: Đọc các tệp log (log files), sự kiện hệ thống và gửi trực tiếp đến Elasticsearch mà không cần qua bộ xử lý trung gian nặng nề, giúp tiết kiệm tài nguyên CPU/RAM cho hệ thống Lab.

2.2.3. Ưu điểm của kiến trúc Direct Ingest

- Triển khai đơn giản, giảm bớt điểm lỗi (Point of Failure) do loại bỏ lớp Logstash trung gian.
- Tiết kiệm tài nguyên phần cứng, phù hợp cho các mô hình vừa và nhỏ hoặc môi trường thử nghiệm.
- Giảm độ trễ (Latency) từ lúc sự kiện xảy ra đến lúc hiển thị trên Dashboard.

2.3. Giới thiệu về Wazuh

2.3.1. Tổng quan

Wazuh là nền tảng bảo mật mã nguồn mở, hợp nhất các khả năng của XDR (Extended Detection and Response) và SIEM. Nó cung cấp khả năng bảo vệ thống nhất cho các môi trường điện toán đám mây và tại chỗ (on-premise).

2.3.2. Kiến trúc hệ thống Wazuh

Hệ thống Wazuh trong đồ án hoạt động theo cơ chế Client-Server:

1. **Wazuh Agent:** Cài đặt trên các endpoint (trong đồ án là Ubuntu Server và Nginx Web Server). Agent chịu trách nhiệm thu thập thông tin hệ thống, giám sát tính toàn vẹn tệp tin (FIM) và phát hiện các bất thường cấp độ máy trạm.
2. **Wazuh Manager:** Thành phần trung tâm chịu trách nhiệm nhận dữ liệu từ các Agent, giải mã (decode) log, so khớp với bộ luật (Ruleset) để phát hiện tấn công và sinh ra cảnh báo (Alert).

Cơ chế tích hợp ELK:

3. Wazuh Manager ghi cảnh báo vào tệp alerts.json.
4. Filebeat cài trên Wazuh Manager sẽ đọc tệp này và đẩy trực tiếp sang Elasticsearch.
5. Người dùng xem cảnh báo trên Wazuh Dashboard (một plugin tùy biến của Kibana).

2.3.3. Các tính năng chính

- **Log Analysis:** Phân tích log hệ thống (Syslog, Auth.log) và log ứng dụng (Nginx).
- **File Integrity Monitoring:** Giám sát sự thay đổi trái phép của các tệp tin cấu hình quan trọng và mã nguồn website.
- **Vulnerability Detection:** Quét và phát hiện lỗ hổng phần mềm.

- **Active Response:** Tự động phản ứng khi phát hiện mối đe dọa (block IP, disable account...).
- **Integration:** Hỗ trợ tích hợp Suricata, Zeek, VirusTotal, OSQuery,...

2.4. Các công cụ hỗ trợ trong mô hình

2.4.1. Nginx Web Server

Nginx là một máy chủ web (Web Server) mã nguồn mở hiệu năng cao. Trong phạm vi đồ án, Nginx được cài đặt trên máy ảo VM3 để đóng vai trò là "máy nạn nhân" (Victim) chạy ứng dụng web mục tiêu. Các tệp nhật ký của Nginx, bao gồm access.log (ghi nhận truy cập) và error.log (ghi nhận lỗi), là nguồn dữ liệu quan trọng giúp hệ thống phát hiện các hành vi dò quét và tấn công vào lớp ứng dụng như SQL Injection hay XSS.

2.4.2. Suricata (IDS)

Suricata là hệ thống phát hiện xâm nhập mạng (Network IDS) mã nguồn mở, có khả năng giám sát lưu lượng mạng theo thời gian thực.

- **Vai trò:** Suricata phân tích các gói tin đi vào máy chủ Web (VM3) và so khớp với bộ luật (Ruleset/Signatures) để phát hiện các dấu hiệu tấn công nguy hiểm mà log hệ thống thông thường có thể bỏ sót.
- **Cơ chế:** Kết quả phân tích được ghi vào tệp nhật ký eve.json (định dạng JSON). Wazuh Agent sẽ đọc tệp này để gửi cảnh báo về trung tâm xử lý.

2.4.3. Filebeat

Filebeat là một tác nhân vận chuyển log (log shipper) hạng nhẹ thuộc hệ sinh thái Elastic.

- **Vai trò:** Trong kiến trúc Direct Ingest của đồ án, Filebeat thay thế hoàn toàn vai trò của Logstash.
- **Nhiệm vụ:** Nó được cài đặt trên các máy trạm để thu thập log từ các nguồn (như log Nginx, log hệ thống), tự động phân tích cú pháp (parsing) thông qua các module tích hợp sẵn và gửi trực tiếp dữ liệu về Elasticsearch để lưu trữ.

2.5. Các kỹ thuật phát hiện tấn công mạng

2.5.1. SSH Brute-Force

- **Mô tả:** Kẻ tấn công thực hiện kỹ thuật dò đoán mật khẩu nhiều lần liên tiếp nhằm chiếm quyền truy cập trái phép vào máy chủ thông qua giao thức SSH.
- **Cơ chế phát hiện:** Wazuh Agent thu thập log xác thực tại /var/log/auth.log (trên Ubuntu). Wazuh Manager sử dụng bộ luật (Ruleset) để đếm số lần đăng nhập thất bại từ cùng một địa chỉ IP trong khoảng thời gian nhất định (ví dụ: 8 lần trong 60 giây). Nếu vượt ngưỡng, cảnh báo sẽ được kích hoạt.

2.5.2. SQL Injection (SQLi)

- **Mô tả:** Tấn công chèn các câu lệnh SQL độc hại vào dữ liệu đầu vào (input) của ứng dụng web nhằm thao túng cơ sở dữ liệu (xem, sửa, xóa dữ liệu trái phép).
- **Cơ chế phát hiện:** Hệ thống IDS Suricata giám sát lưu lượng mạng HTTP đến Web Server. Nó so khớp nội dung gói tin với các chữ ký (signatures) chứa các từ khóa SQL nhạy cảm như UNION SELECT, ' OR '1'='1, DROP TABLE,... để phát hiện payload tấn công.

2.5.3. Cros-Site Scripting (XSS)

- **Mô tả:** Kẻ tấn công chèn các đoạn mã kịch bản độc hại (thường là JavaScript) vào trang web để thực thi trên trình duyệt của người dùng khác.
- **Cơ chế phát hiện:** Suricata phân tích các yêu cầu HTTP (GET/POST) để tìm kiếm các thẻ hoặc sự kiện JavaScript nguy hiểm trong URL hoặc Body request, ví dụ: <script>, javascript:, onload=, alert(),....

2.5.4. Local File Inclusion (LFI)

- **Mô tả:** Tấn công lợi dụng lỗ hổng trong cơ chế "include" file của ứng dụng web (như PHP) để đọc các tệp tin hệ thống nhạy cảm nằm ngoài thư mục webroot.
- **Cơ chế phát hiện:** Hệ thống (Suricata hoặc Rule Wazuh phân tích log Nginx) phát hiện các yêu cầu chứa ký tự điều hướng thư mục (../, ..\) hoặc đường dẫn đến các file hệ thống quan trọng như /etc/passwd, /etc/shadow, /var/log/.

2.5.5. File Integrity Monitoring (FIM)

- **Mô tả:** Kỹ thuật theo dõi và phát hiện sự thay đổi bất thường (tạo mới, chỉnh sửa, xóa) trên các tệp tin cấu hình hệ thống hoặc mã nguồn ứng dụng web.
- **Cơ chế phát hiện:** Module Syscheck của Wazuh Agent định kỳ quét và lưu trữ mã băm (checksum MD5/SHA1/SHA256) của các file được giám sát. Khi mã băm thay đổi so với cơ sở dữ liệu ban đầu, Agent gửi log cảnh báo tức thì về Manager (độ trễ thường dưới 5 giây).

2.6. Các chỉ số đánh giá hiệu quả phát hiện

- **Precision (Độ chính xác):**
 - **Công thức:** $Precision = TP / (TP + FP)$
 - **Ý nghĩa:** Phản ánh tỷ lệ các cảnh báo tấn công là chính xác trên tổng số cảnh báo hệ thống đưa ra. Chỉ số này càng cao chứng tỏ hệ thống ít đưa ra các cảnh báo giả (False Alarm) gây nhiễu cho người quản trị.
- **Recall (Độ bao phủ/Độ nhạy):**
 - **Công thức:** $Recall = TP / (TP + FN)$
 - **Ý nghĩa:** Phản ánh khả năng phát hiện của hệ thống, tức là tỷ lệ số cuộc tấn công được phát hiện trên tổng số cuộc tấn công thực tế đã diễn ra. Recall cao đồng nghĩa với việc hệ thống ít bỏ sót các mối đe dọa (False Negative).
- **F1-Score:**
 - **Công thức:** $F1 = 2 * (Precision * Recall) / (Precision + Recall)$
 - **Ý nghĩa:** Là trung bình điều hòa giữa Precision và Recall. Chỉ số này được dùng để đánh giá tổng quát sự cân bằng giữa độ chính xác và độ bao phủ của mô hình.
- **False Positive Rate (FPR - Tỷ lệ cảnh báo sai):**
 - **Công thức:** $FPR = FP / (FP + TN)$
 - **Ý nghĩa:** Tỷ lệ các hành vi bình thường bị hệ thống nhận diện nhầm là tấn công. Mục tiêu của đề án là giữ chỉ số này ở mức thấp nhất (dưới 5%).
- **Latency (Độ trễ xử lý):**
 - **Định nghĩa:** Là khoảng thời gian trễ tính từ lúc hành vi tấn công xảy ra (được ghi nhận tại log gốc hoặc gói tin mạng) cho đến khi cảnh báo tương ứng xuất hiện trên Dashboard của Kibana.

- **Mục tiêu:** Trong mô hình Direct Ingest (không qua Logstash), độ trễ kỳ vọng là dưới 5 giây đối với FIM và dưới 10 giây đối với các tấn công phân tích log phức tạp.

2.7. Tích hợp nâng cao (SOAR / AI/ML)

2.7.1. SOAR mini

- Khi SSH brute-force vượt ngưỡng → tự động block IP qua iptables/ufw.
- Khi burst 4625 xảy ra → tự động khóa tài khoản tạm thời.

2.7.2. AI/ML

- Áp dụng thuật toán Isolation Forest, Random Forest, XGBoost để phát hiện hành vi bất thường từ log web.
- Dựa trên các đặc trưng như: entropy của URI, tần suất truy cập, mã trạng thái HTTP,...

2.8. Kết luận chương

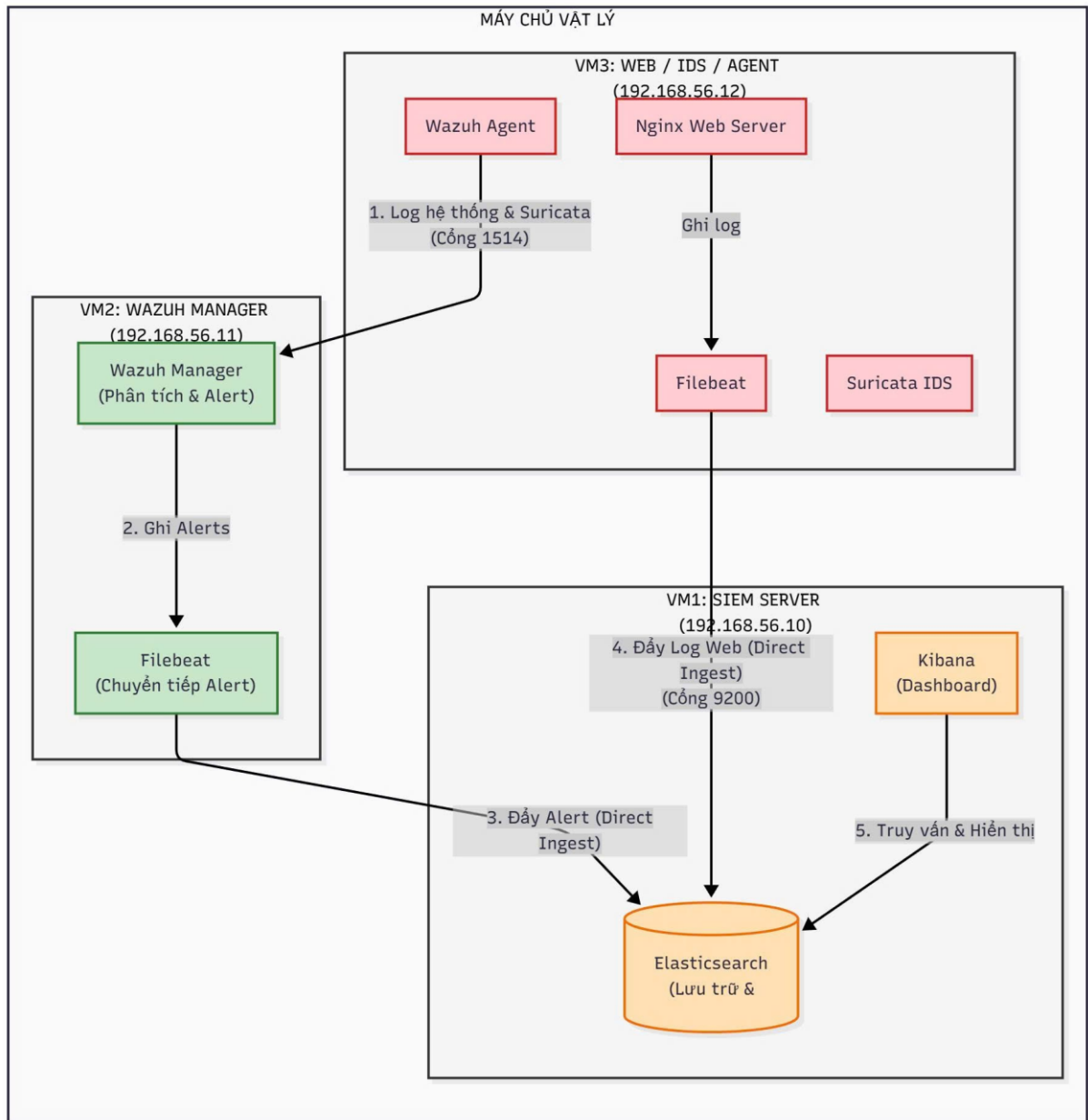
Chương 2 đã trình bày hệ thống các cơ sở lý thuyết quan trọng về SIEM và kiến trúc công nghệ lõi được sử dụng trong đề án. Cụ thể, chương đã làm rõ cơ chế hoạt động của Wazuh (HIDS), Suricata (NIDS) và bộ công cụ ELK Stack theo mô hình thu thập trực tiếp (Direct Ingest) giúp tối ưu hóa hiệu năng.

Sự kết hợp giữa giám sát cấp độ máy trạm (Wazuh) và giám sát lưu lượng mạng (Suricata) tạo nên một lớp phòng thủ đa chiều vững chắc. Bên cạnh đó, việc tích hợp cơ chế phản ứng tự động (Active Response) cho phép hệ thống không chỉ dừng lại ở việc cảnh báo mà còn có khả năng ngăn chặn mối đe dọa trong thời gian thực. Đây là những tiền đề lý thuyết vững chắc để nhóm nghiên cứu tiến hành thiết kế và triển khai hệ thống chi tiết trong Chương 3.

CHƯƠNG 3: THIẾT KẾ HỆ THỐNG VÀ KẾT QUẢ THỰC NGHIỆM

3.1. Giới thiệu chương

Chương này trình bày toàn bộ quá trình triển khai hệ thống SIEM dựa trên Wazuh và ELK theo mô hình Direct Ingest. Nội dung bao gồm các bước chuẩn bị hạ tầng, cài đặt các thành phần chính, cấu hình pipeline log, mô phỏng các kịch bản tấn công và phân tích kết quả nhận được trên Dashboard. Các mục sau sẽ giải thích lý thuyết, quy trình thực hiện và minh chứng trên hình ảnh.



Hình 1: Hình ảnh mô hình hoạt động

3.2. Chuẩn bị hạ tầng & mạng

Lý thuyết thực hiện

- Trong giai đoạn đầu tiên, cần xây dựng mô hình mạng phòng Lab bao gồm 03 máy ảo đóng vai trò chuyên biệt: SIEM Server (VM1), Wazuh Manager (VM2), và

Web/IDS/Agent (VM3). Việc phân tách này giúp mô phỏng môi trường doanh nghiệp thực tế, đảm bảo tính độc lập giữa tầng thu thập (Agent/IDS), tầng quản lý (Manager) và tầng lưu trữ/hiển thị (Elasticsearch/Kibana).

- Đặc biệt, mô hình mạng này cần được cấu hình IP tĩnh (Static IP) để duy trì kết nối ổn định cho luồng dữ liệu Direct Ingest (từ Filebeat/Agent thẳng về Elasticsearch/Manager). Bên cạnh đó, việc đồng bộ thời gian (NTP) giữa các máy là bước tiên quyết để đảm bảo tính chính xác của timestamp trong log, phục vụ cho việc tương quan sự kiện và tính toán độ trễ (Latency) sau này.

• Các bước thực hiện

Đặt IP tĩnh cho từng VM:

VM1(SIEM-UBUNTU)=192.168.56.10

VM2(WAZUH-UBUNTU)=192.168.56.11

VM3(WEB-UBUNTU)=192.168.56.12.

Kiểm tra kết nối giữa các máy bằng ping và đảm bảo có thể truy cập Internet.

```

trung@siem-ubuntu01: ~
3 packets transmitted, 3 received, 0% packet loss, time 2023ms
rtt min/avg/max/mdev = 0.423/0.753/1.304/0.391 ms
trung@siem-ubuntu01:~$ ping -c 3 192.168.56.12
PING 192.168.56.12 (192.168.56.12) 56(84) bytes of data.
64 bytes from 192.168.56.12: icmp_seq=1 ttl=64 time=0.513 ms
64 bytes from 192.168.56.12: icmp_seq=2 ttl=64 time=0.265 ms
64 bytes from 192.168.56.12: icmp_seq=3 ttl=64 time=0.347 ms

--- 192.168.56.12 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2035ms
rtt min/avg/max/mdev = 0.265/0.375/0.513/0.103 ms
trung@siem-ubuntu01:~$ ping -c 3 google.com
PING google.com (142.251.10.138) 56(84) bytes of data.
64 bytes from sd-in-f138.1e100.net (142.251.10.138): icmp_seq=1 ttl=128 time=46.4 ms
64 bytes from sd-in-f138.1e100.net (142.251.10.138): icmp_seq=2 ttl=128 time=45.7 ms
64 bytes from sd-in-f138.1e100.net (142.251.10.138): icmp_seq=3 ttl=128 time=46.2 ms

--- google.com ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2004ms
rtt min/avg/max/mdev = 45.744/46.103/46.367/0.263 ms
trung@siem-ubuntu01:~$

```

Hình 2: Ping thành công từ SIEM tới WAZUH, WEB

```

trung@wazuh-ubuntu01:~$ ping -c 3 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=0.491 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.387 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.397 ms

--- 192.168.56.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2010ms
rtt min/avg/max/mdev = 0.387/0.425/0.491/0.046 ms
trung@wazuh-ubuntu01:~$ ping -c 3 192.168.56.12
PING 192.168.56.12 (192.168.56.12) 56(84) bytes of data.
64 bytes from 192.168.56.12: icmp_seq=1 ttl=64 time=0.524 ms
64 bytes from 192.168.56.12: icmp_seq=2 ttl=64 time=0.402 ms
64 bytes from 192.168.56.12: icmp_seq=3 ttl=64 time=0.600 ms

--- 192.168.56.12 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2038ms
rtt min/avg/max/mdev = 0.402/0.508/0.600/0.081 ms
trung@wazuh-ubuntu01:~$

```

Hình 3: Ping thành công từ wazuh đến siem và web

```

trung@web-ubuntu01:~$ ping -c 3 192.168.56.10
PING 192.168.56.10 (192.168.56.10) 56(84) bytes of data.
64 bytes from 192.168.56.10: icmp_seq=1 ttl=64 time=0.441 ms
64 bytes from 192.168.56.10: icmp_seq=2 ttl=64 time=0.417 ms
64 bytes from 192.168.56.10: icmp_seq=3 ttl=64 time=0.347 ms

--- 192.168.56.10 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2055ms
rtt min/avg/max/mdev = 0.347/0.401/0.441/0.039 ms
trung@web-ubuntu01:~$ ping -c 3 192.168.56.11
PING 192.168.56.11 (192.168.56.11) 56(84) bytes of data.
64 bytes from 192.168.56.11: icmp_seq=1 ttl=64 time=0.376 ms
64 bytes from 192.168.56.11: icmp_seq=2 ttl=64 time=0.394 ms
64 bytes from 192.168.56.11: icmp_seq=3 ttl=64 time=0.256 ms

--- 192.168.56.11 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2073ms
rtt min/avg/max/mdev = 0.256/0.342/0.394/0.061 ms
trung@web-ubuntu01:~$

```

Hình 4: Ping thành công từ web đến siem và wazuh

3.3. Cài Elasticsearch

Lý thuyết thực hiện

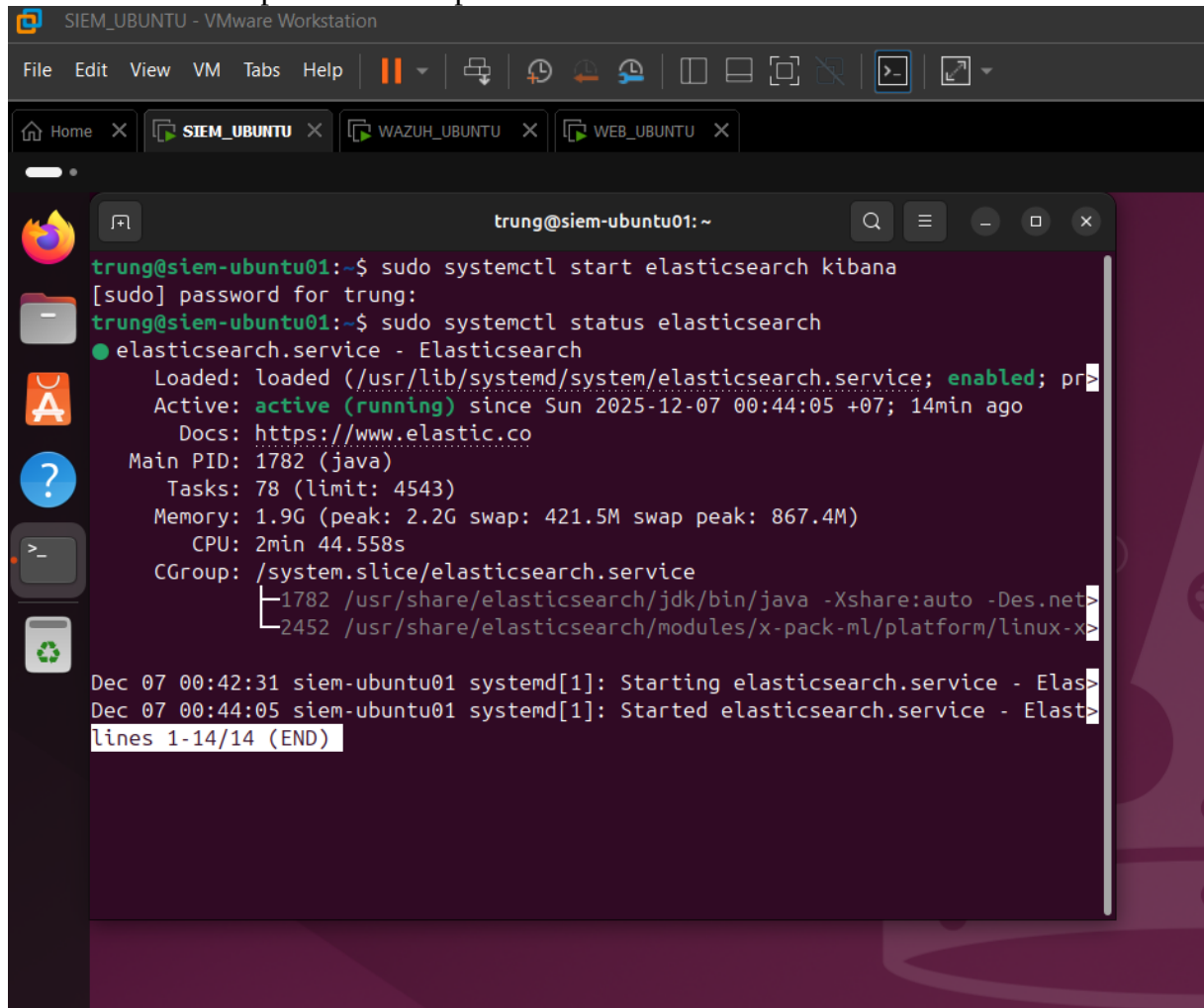
Elasticsearch là hệ thống lưu trữ log dạng tài liệu, được tối ưu cho các truy vấn tốc độ cao và phân tích thời gian thực. Nó vận hành dựa trên mô hình phân mảnh dữ liệu, cho phép mở rộng tuyến tính khi dung lượng log tăng cao. Trong bài này, Elasticsearch giữ vai trò trung tâm, tiếp nhận log từ Filebeat và cảnh báo từ Wazuh Manager thông qua giao thức HTTPS. Việc bật tính năng bảo mật X-Pack đảm bảo các kết nối đều yêu cầu xác thực, giảm thiểu nguy cơ tấn công giả mạo hoặc chen log độc hại. Chứng chỉ CA được dùng để thiết lập kênh TLS an toàn, đồng thời giúp các Agent có thể tin cậy vào máy chủ Elasticsearch khi gửi log.

Lệnh thực hiện

```
sudo apt install elasticsearch
```

```
sudo systemctl enable elasticsearch --now
```

```
curl -k -u elastic:<password> https://192.168.56.10:9200
```



Hình 5: Hình ảnh Elasticsearch hoạt động

3.4. Cài Kibana

Lý thuyết thực hiện

Kibana là giao diện trực quan hóa log của Elasticsearch, cung cấp các công cụ quan sát, dashboard và chức năng phân tích chuyên sâu. Vai trò của Kibana trong hệ thống SIEM là cho phép người quản trị kiểm tra log, tạo Data View, theo dõi cảnh báo và thiết lập các cơ chế giám sát nâng cao. Kết nối giữa Kibana và Elasticsearch phải được cấu hình thông qua giao thức HTTPS với chứng chỉ CA nhằm đảm bảo dữ liệu hiển thị là xác

thực và không bị sửa đổi. Kibana cũng là nơi triển khai Watcher – công cụ gửi email cảnh báo khi xuất hiện sự kiện bất thường. Với khả năng hiển thị thời gian thực, Kibana trở thành thành phần quan trọng trong quy trình phân tích sự cố.

Lệnh thực hiện

`sudo apt install kibana`

`sudo systemctl start kibana`

`sudo nano /etc/kibana/kibana.yml`

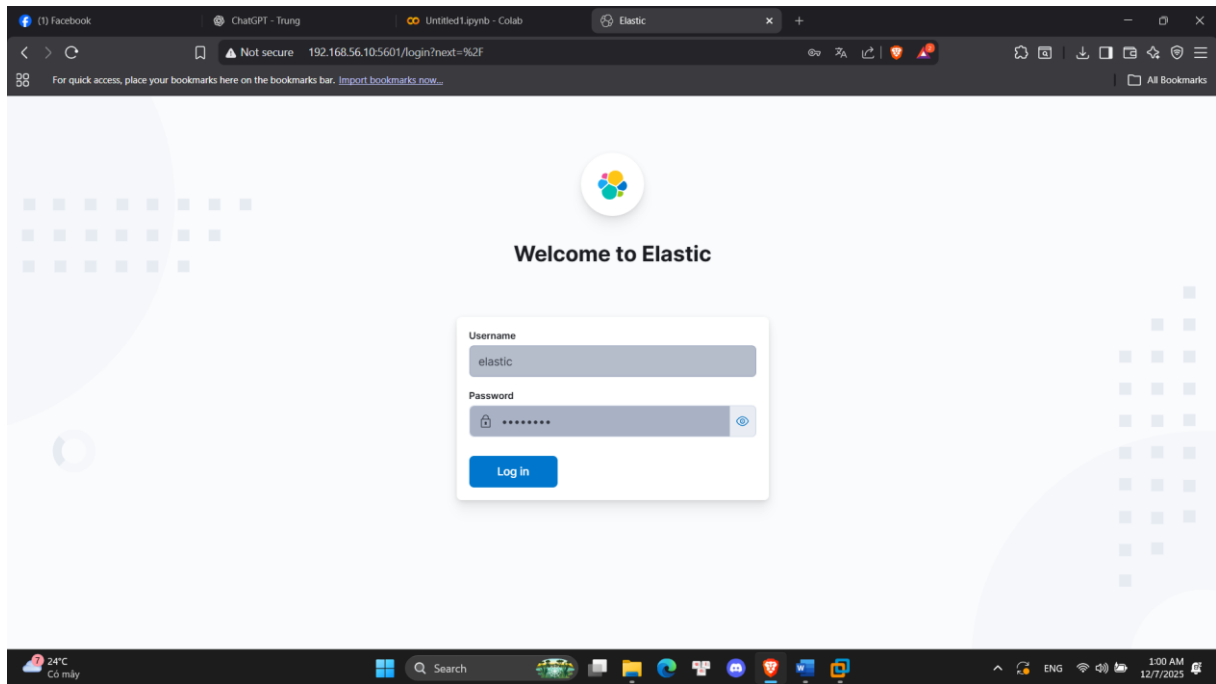
The screenshot shows a terminal window titled 'SIEM_UBUNTU - VMware Workstation'. The terminal is running the command `sudo systemctl status kibana`. The output shows that the `kibana.service` is loaded, enabled, and active (running) since Sun 2025-12-07 00:42:31 +07; 17min ago. The main PID is 1786 (node). The tasks are 11 (limit: 4543). The memory usage is 317.1M (peak: 614.5M swap: 72.2M swap peak: 76.2M). The CPU usage is 41.686s. The CGroup is `/system.slice/kibana.service`. The terminal also shows the command `lines 1-13/13 (END)`.

```

SIEM_UBUNTU - VMware Workstation
File Edit View VM Tabs Help
Home x SIEM_UBUNTU x WAZUH_UBUNTU x WEB_UBUNTU x
trung@siem-ubuntu01: ~
trung@siem-ubuntu01:~$ sudo systemctl status kibana
● kibana.service - Kibana
   Loaded: loaded (/etc/systemd/system/kibana.service; enabled; preset: enable>
   Active: active (running) since Sun 2025-12-07 00:42:31 +07; 17min ago
     Docs: https://www.elastic.co
   Main PID: 1786 (node)
    Tasks: 11 (limit: 4543)
   Memory: 317.1M (peak: 614.5M swap: 72.2M swap peak: 76.2M)
      CPU: 41.686s
   CGroup: /system.slice/kibana.service
           └─1786 /usr/share/kibana/bin/./node/bin/node /usr/share/kibana/bi>
Dec 07 00:42:31 siem-ubuntu01 systemd[1]: Started kibana.service - Kibana.
Dec 07 00:42:33 siem-ubuntu01 kibana[1786]: Kibana is currently running with le>
lines 1-13/13 (END)

```

Hình 6: Hình ảnh kibana hoạt động



Hình 7: Giao diện đăng nhập Kibana

3.5. Cài Wazuh Manager

Lý thuyết thực hiện

Wazuh Manager là trung tâm phân tích an ninh của hệ thống, chịu trách nhiệm xử lý log từ các Agent và Suricata. Khi nhận log, Manager tiến hành giải mã, chuẩn hóa và so khớp với bộ quy tắc nhằm xác định hành vi bất thường theo MITRE ATT&CK. Lóp Manager phải vận hành ổn định, vì toàn bộ quá trình phát hiện tấn công phụ thuộc vào nó. Kiểm tra trạng thái dịch vụ giúp đảm bảo rằng Manager đang nhận log, xử lý đúng pipeline và sẵn sàng sinh cảnh báo. Manager cũng chịu trách nhiệm tạo tệp alerts.json làm đầu vào cho Filebeat.

Lệnh thực hiện

```
sudo apt install wazuh-manager
sudo systemctl status wazuh-manager
sudo tail -f /var/ossec/logs/ossec.log
```

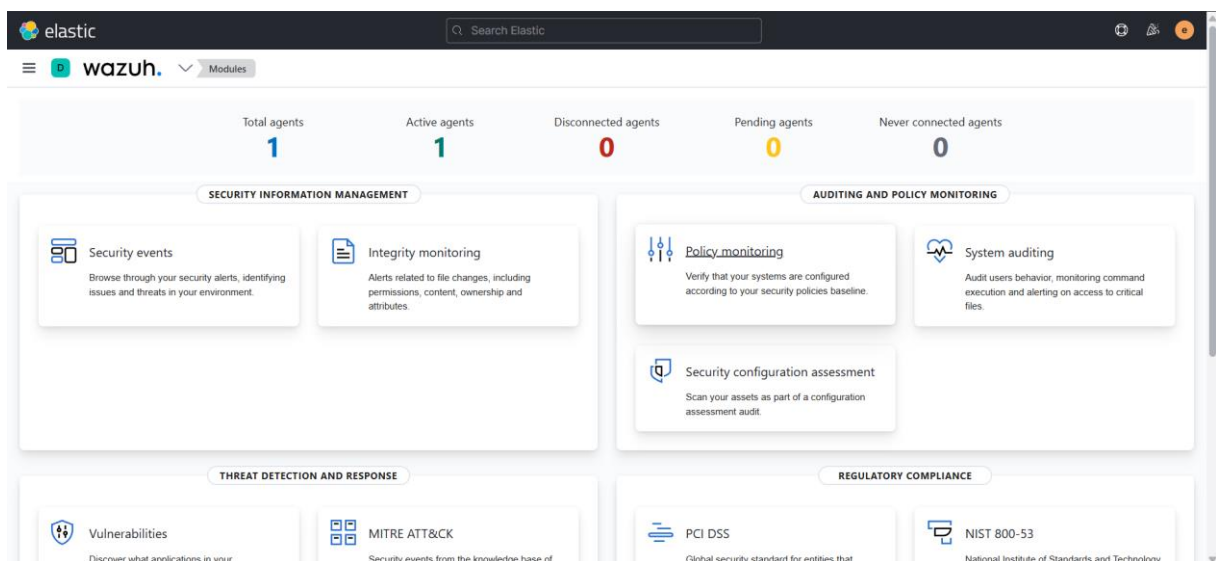
```

WAZUH_UBUNTU - VMware Workstation
File Edit View VM Tabs Help
Home X SIEM_UBUNTU X WAZUH_UBUNTU X WEB_UBUNTU X

trung@wazuh-ubuntu01: ~
trung@wazuh-ubuntu01:~$ sudo systemctl start wazuh-manager filebeat
[sudo] password for trung:
trung@wazuh-ubuntu01:~$ sudo systemctl status wazuh-manager
[sudo] password for trung:
● wazuh-manager.service - Wazuh manager
   Loaded: loaded (/usr/lib/systemd/system/wazuh-manager.service; enabled; pr>
   Active: active (running) since Sun 2025-12-07 00:43:01 +07; 18min ago
   Process: 1693 ExecStart=/usr/bin/env /var/ossec/bin/wazuh-control start (co>
   Tasks: 107 (limit: 4543)
   Memory: 795.6M (peak: 798.3M)
   CPU: 56.498s
   CGroup: /system.slice/wazuh-manager.service
           └─2264 /var/ossec/framework/python/bin/python3 /var/ossec/api/scri>
             2306 /var/ossec/bin/wazuh-authd
             2323 /var/ossec/bin/wazuh-db
             2350 /var/ossec/bin/wazuh-execd
             2353 /var/ossec/framework/python/bin/python3 /var/ossec/api/scri>
             2356 /var/ossec/framework/python/bin/python3 /var/ossec/api/scri>
             2372 /var/ossec/bin/wazuh-analysisd
             2389 /var/ossec/bin/wazuh-syscheckd
             2428 /var/ossec/bin/wazuh-remoted
             2464 /var/ossec/bin/wazuh-logcollector
             2486 /var/ossec/bin/wazuh-monitord
             2510 /var/ossec/bin/wazuh-modulesd

```

Hình 8: Hình ảnh Manager hoạt động



Hình 9: Trạng thái Manager hiển thị trong Dashboard

3.6. Filebeat trên VM2

Lý thuyết thực hiện

Filebeat là tác nhân thu thập log nhẹ, được thiết kế để vận chuyển dữ liệu hiệu quả đến Elasticsearch. Module wazuh giúp Filebeat tự động phân tích tệp alerts.json thành các trường thuộc chuẩn ECS, hỗ trợ truy vấn dễ dàng hơn trong Kibana. Pipeline này loại bỏ nhu cầu sử dụng Logstash, giúp giảm độ trễ và phù hợp với mô hình Direct Ingest. Quá trình kiểm tra đầu ra đảm bảo rằng Filebeat có thể kết nối với Elasticsearch thông qua TLS và xác thực đúng người dùng. Khi cấu hình đúng, các alert sẽ được gửi lên chỉ sau vài giây.

Lệnh thực hiện

```
sudo apt install filebeat
```

```
sudo filebeat modules enable wazuh
```

```
sudo filebeat test output
```

The screenshot shows a terminal window titled 'WAZUH_UBUNTU - VMware Workstation'. The terminal is running the command 'sudo systemctl status filebeat'. The output shows that the filebeat.service is loaded and enabled, and is currently active (running) since Sun 2025-12-07 00:42:33 +07; 22min ago. The main PID is 1691, and it has 7 tasks, 114.9M memory, and 1.080s CPU. The CGroup is /system.slice/filebeat.service. Below the status, there is a list of log entries from filebeat[1691] showing timestamps and log data.

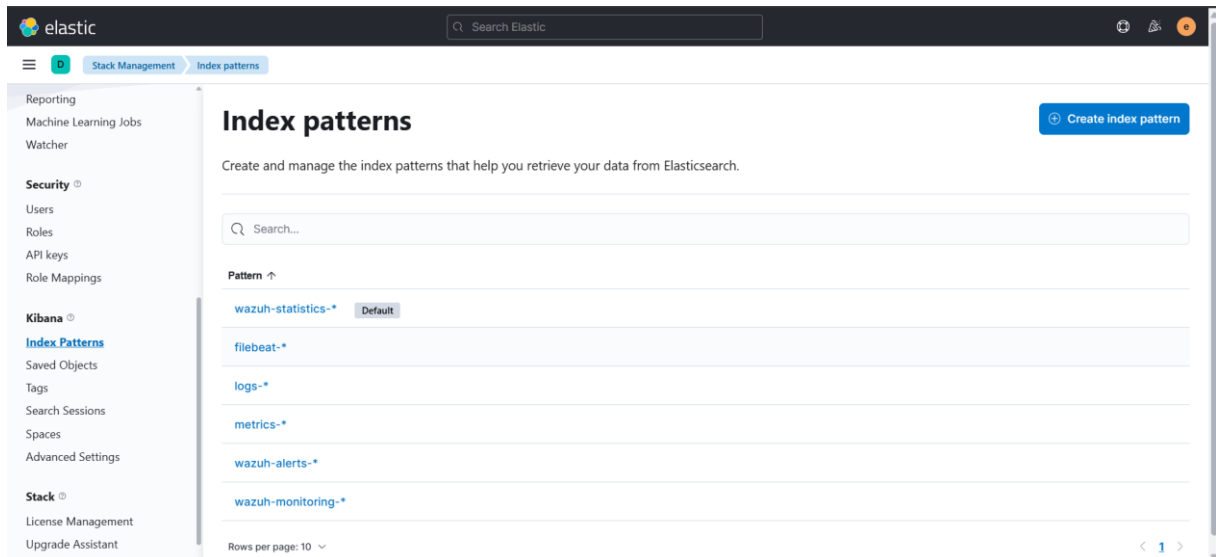
```

trung@wazuh-ubuntu01:~$ sudo systemctl status filebeat
● filebeat.service - Filebeat sends log files to Logstash or directly to Elasti>
   Loaded: loaded (/usr/lib/systemd/system/filebeat.service; enabled; preset:~>
   Active: active (running) since Sun 2025-12-07 00:42:33 +07; 22min ago
     Docs: https://www.elastic.co/beats/filebeat
    Main PID: 1691 (filebeat)
      Tasks: 7 (limit: 4543)
    Memory: 114.9M (peak: 119.7M)
       CPU: 1.080s
    CGroup: /system.slice/filebeat.service
            └─1691 /usr/share/filebeat/bin/filebeat --environment systemd -c />

Dec 07 01:00:37 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:00:37.556+0700
Dec 07 01:01:07 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:01:07.556+0700
Dec 07 01:01:37 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:01:37.562+0700
Dec 07 01:01:57 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:01:57.792+0700
Dec 07 01:02:07 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:02:07.558+0700
Dec 07 01:02:37 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:02:37.556+0700
Dec 07 01:03:07 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:03:07.608+0700
Dec 07 01:03:37 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:03:37.558+0700
Dec 07 01:04:07 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:04:07.567+0700
Dec 07 01:04:37 wazuh-ubuntu01 filebeat[1691]: 2025-12-07T01:04:37.558+0700
lines 1-21/21 (END)

```

Hình 10: Giao diện filebeat trên VM2 hoạt động



Hình 11: Index `wazuh-alerts-*` xuất hiện trong Elasticsearch

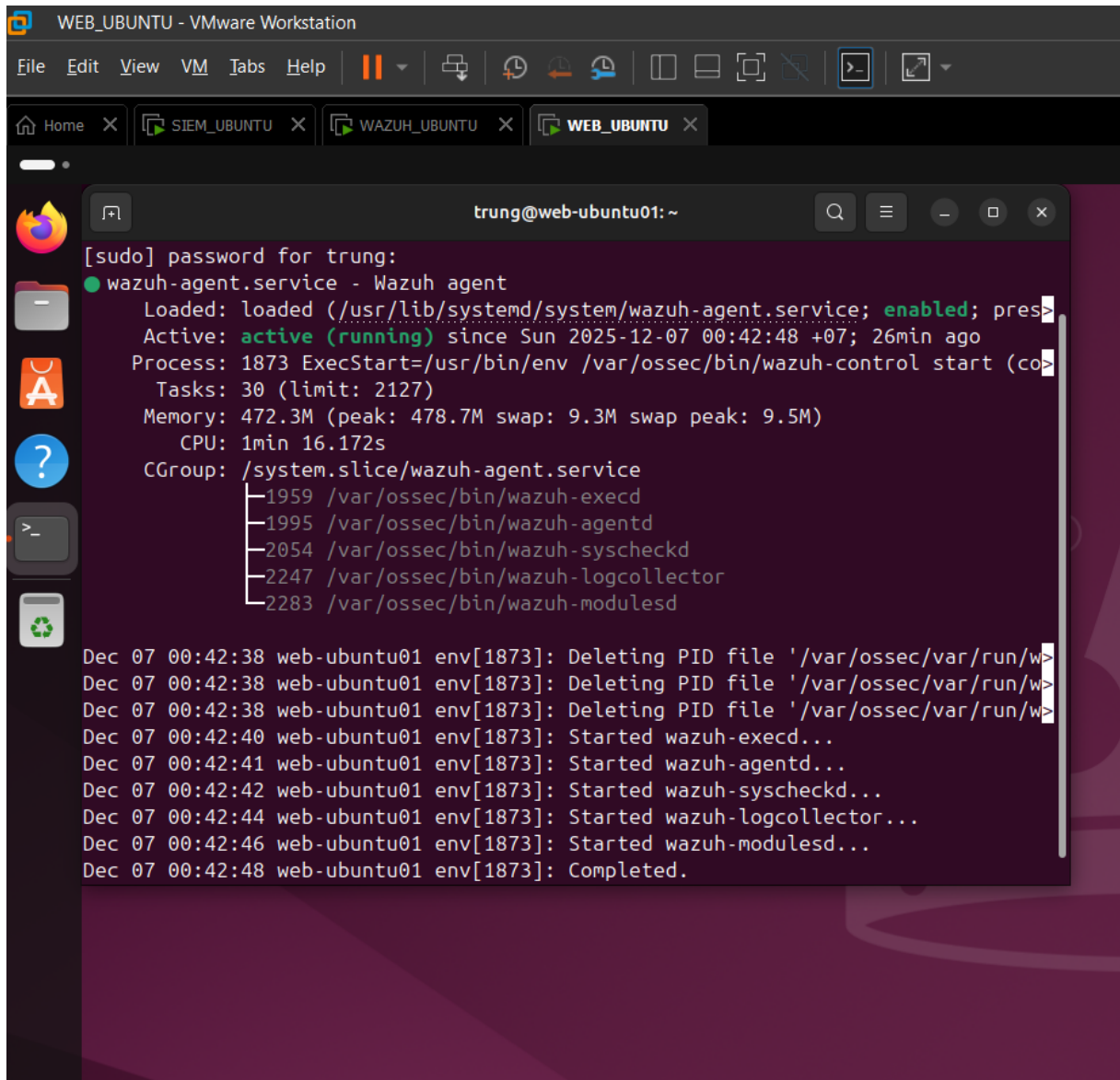
3.7. Cài đặt Wazuh Agent

Lý thuyết thực hiện

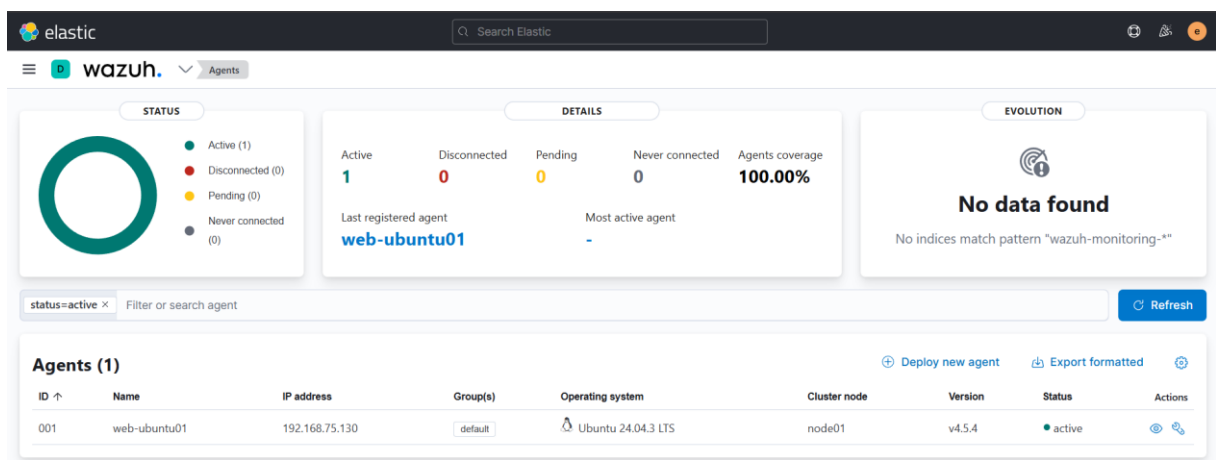
Wazuh Agent thu thập các loại log từ hệ thống như syslog, service log, giám sát file (FIM), log Suricata và metadata thiết bị. Agent kết nối tới Manager bằng giao thức được mã hóa, đảm bảo log không bị chặn hoặc sửa đổi giữa đường. Trong kiến trúc SIEM, Agent đóng vai trò lớp thu thập dữ liệu quan trọng nhất. Khi Agent được kích hoạt, nó sẽ gửi heartbeat định kỳ để Manager xác minh trạng thái hoạt động. Sự ổn định của Agent đảm bảo dữ liệu từ VM3 luôn được phản ánh đúng trong Dashboard.

Lệnh thực hiện

```
sudo apt install wazuh-agent
sudo nano /var/ossec/etc/ossec.conf
sudo systemctl restart wazuh-agent
```



Hình 12: Agent hoạt động trên VM3



Hình 13: Agent hiển thị Active trong Wazuh Dashboard

3.8. Cài đặt Suricata IDS

Lý thuyết thực hiện

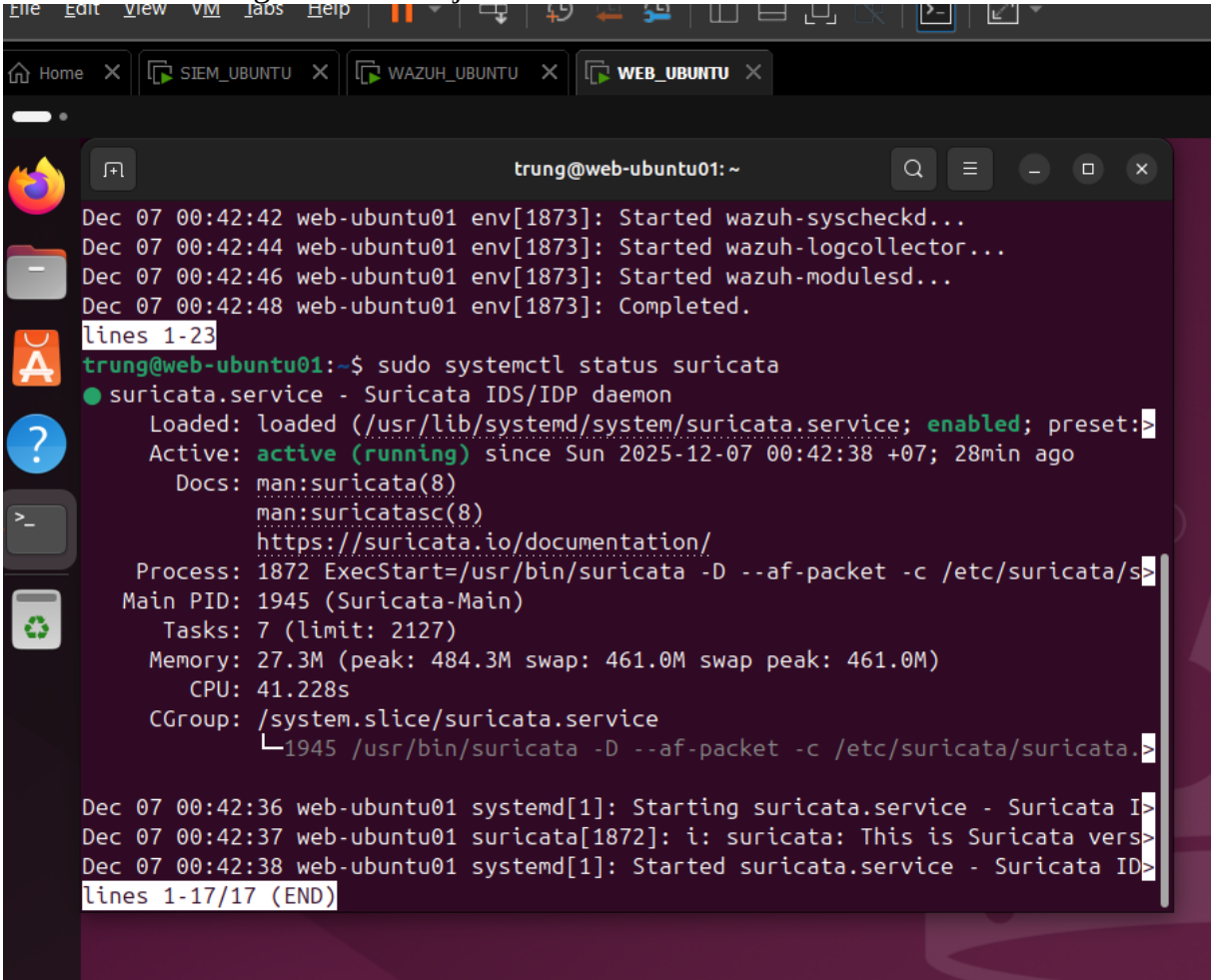
Suricata là hệ thống phát hiện xâm nhập dựa trên signatures, hoạt động ở tầng mạng để phân tích các gói tin HTTP, TCP và UDP. Khi phát hiện payload nghi ngờ như SQLi, XSS hoặc LFI, Suricata tạo bản ghi sự kiện và xuất vào tệp eve.json. Wazuh Agent đọc tệp này và chuyển tiếp đến Manager để phân tích sâu mức độ nguy hiểm. Suricata giúp bổ sung góc nhìn Network-based Detection cho hệ thống SIEM, kết hợp với Host-based Detection từ Wazuh để tạo ra lớp bảo vệ đa tầng. Đây là thành phần quan trọng để mô phỏng các tấn công web thực tế trong môi trường Lab.

Lệnh thực hiện

```
sudo apt install suricata
```

```
sudo systemctl restart suricata
```

```
sudo tail -f /var/log/suricata/eve.json
```



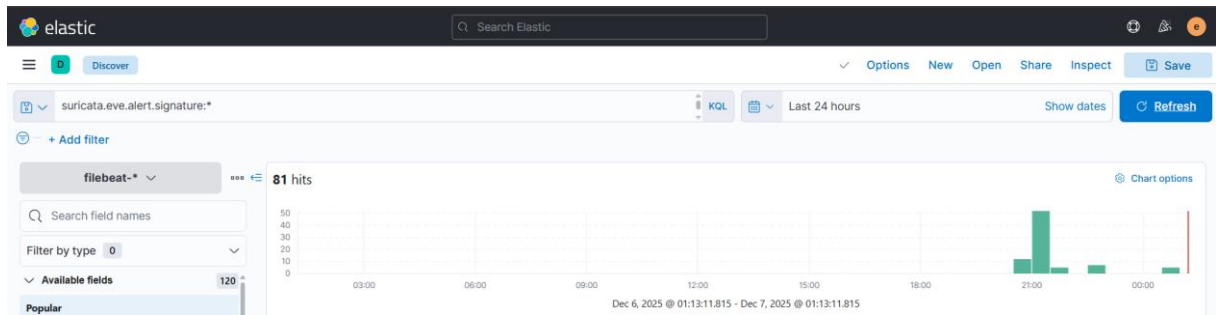
```

Dec 07 00:42:42 web-ubuntu01 env[1873]: Started wazuh-syscheckd...
Dec 07 00:42:44 web-ubuntu01 env[1873]: Started wazuh-logcollector...
Dec 07 00:42:46 web-ubuntu01 env[1873]: Started wazuh-modulesd...
Dec 07 00:42:48 web-ubuntu01 env[1873]: Completed.
lines 1-23
trung@web-ubuntu01:~$ sudo systemctl status suricata
● suricata.service - Suricata IDS/IDP daemon
   Loaded: loaded (/usr/lib/systemd/system/suricata.service; enabled; preset:~>
   Active: active (running) since Sun 2025-12-07 00:42:38 +07; 28min ago
     Docs: man:suricata(8)
           man:suricatasc(8)
           https://suricata.io/documentation/
   Process: 1872 ExecStart=/usr/bin/suricata -D --af-packet -c /etc/suricata/s>
   Main PID: 1945 (Suricata-Main)
     Tasks: 7 (limit: 2127)
    Memory: 27.3M (peak: 484.3M swap: 461.0M swap peak: 461.0M)
       CPU: 41.228s
    CGroup: /system.slice/suricata.service
            └─1945 /usr/bin/suricata -D --af-packet -c /etc/suricata/suricata.>

Dec 07 00:42:36 web-ubuntu01 systemd[1]: Starting suricata.service - Suricata I>
Dec 07 00:42:37 web-ubuntu01 suricata[1872]: i: suricata: This is Suricata vers>
Dec 07 00:42:38 web-ubuntu01 systemd[1]: Started suricata.service - Suricata ID>
lines 1-17/17 (END)

```

Hình 14: Suricata signatures hoạt động



Hình 15: Suricata signatures hiển thị trong Kibana

3.9. Cài Nginx + Filebeat trên VM3

Lý thuyết thực hiện

Nginx được triển khai làm mục tiêu tấn công web, giúp sinh ra log truy cập thực tế để phân tích SIEM. Những log này rất quan trọng, vì nhiều cuộc tấn công ứng dụng để lại dấu vết trực tiếp trong access.log. Filebeat module nginx giúp chuẩn hóa log thành cấu trúc dễ phân tích, hỗ trợ hiển thị rõ ràng các trường như URI, agent, status code. Việc gửi các yêu cầu HTTP thử nghiệm giúp kiểm tra pipeline log từ VM3 đến Elasticsearch. Kết quả chính là nền tảng để phân tích các cuộc tấn công SQLi/XSS/LFI.

Lệnh thực hiện

```
sudo apt install nginx
sudo filebeat modules enable nginx
curl http://192.168.56.12
```

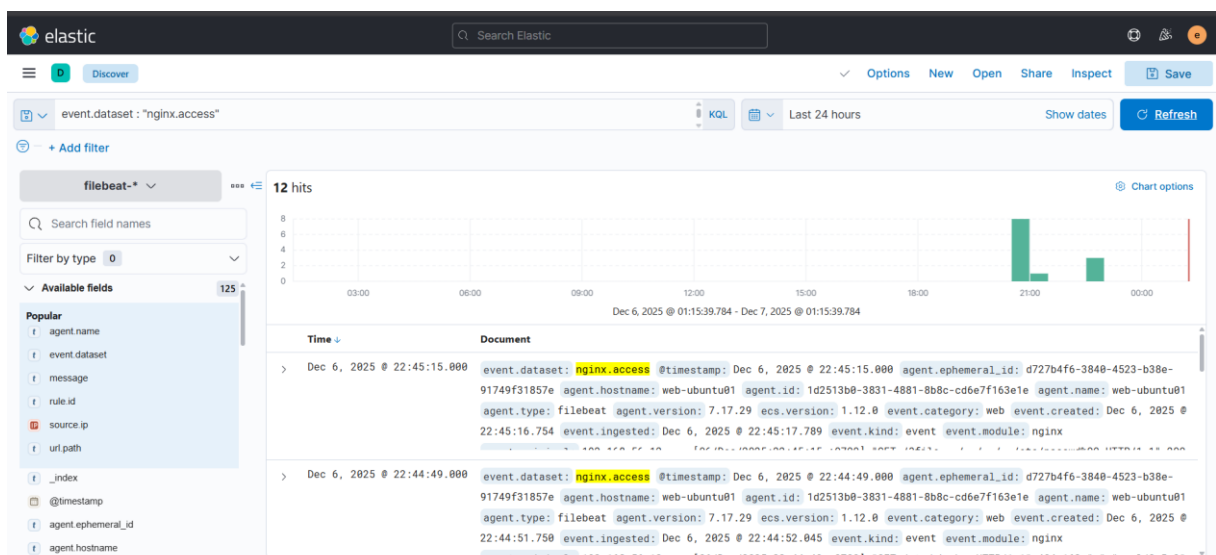
```

trung@web-ubuntu01:~$ sudo systemctl status nginx
● nginx.service - A high performance web server and a reverse proxy server
   Loaded: loaded (/usr/lib/systemd/system/nginx.service; enabled; preset: en>
   Active: active (running) since Sun 2025-12-07 00:42:37 +07; 31min ago
     Docs: man:nginx(8)
  Process: 1871 ExecStartPre=/usr/sbin/nginx -t -q -g daemon on; master_proce>
  Process: 1905 ExecStart=/usr/sbin/nginx -g daemon on; master_process on; (c>
 Main PID: 1916 (nginx)
    Tasks: 2 (limit: 2127)
   Memory: 356.0K (peak: 3.1M swap: 1.4M swap peak: 1.4M)
      CPU: 48ms
   CGroup: /system.slice/nginx.service
           └─1916 "nginx: master process /usr/sbin/nginx -g daemon on; master>
             └─1918 "nginx: worker process"

Dec 07 00:42:36 web-ubuntu01 systemd[1]: Starting nginx.service - A high perfor>
Dec 07 00:42:37 web-ubuntu01 systemd[1]: Started nginx.service - A high perform>
lines 1-16/16 (END)

```

Hình 16: Log Nginx hoạt động trên VM3



Hình 17: Log Nginx hiển thị trong Kibana Discover

3.10. Tạo Data View Kibana

Lý thuyết thực hiện

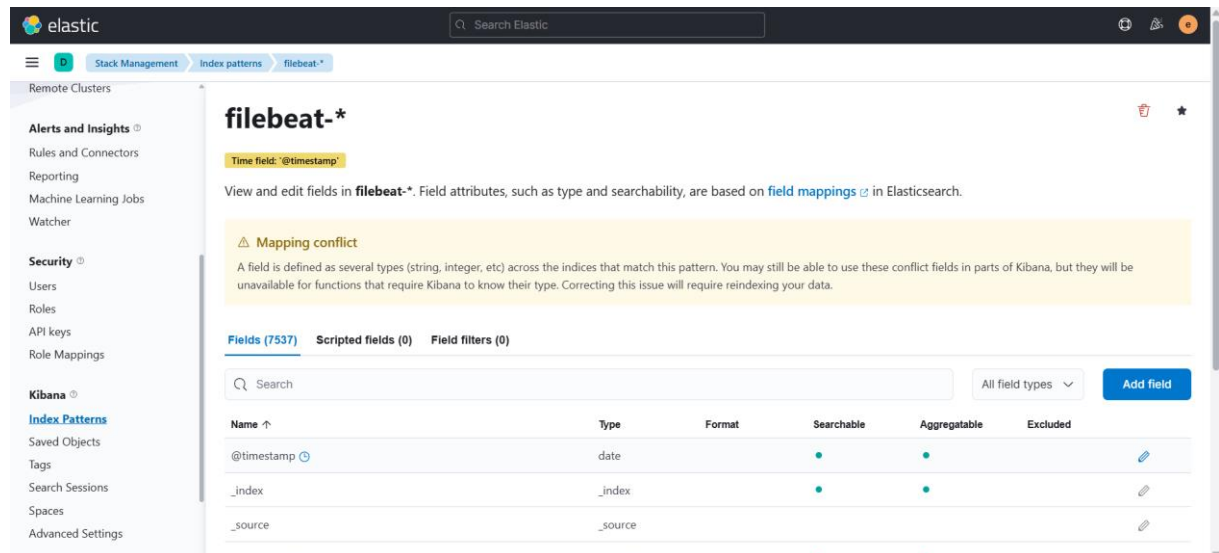
Data View là thành phần cho phép Kibana hiểu cấu trúc dữ liệu đang được lưu trữ trong Elasticsearch. Mỗi Data View đại diện cho một nhóm log khác nhau, giúp người dùng dễ dàng phân tích và trực quan hóa dữ liệu. filebeat-* chứa log hệ thống và web, trong khi wazuh-alerts-* chứa các cảnh báo bảo mật sinh ra từ Wazuh Manager. Việc tạo đúng Data View là điều kiện bắt buộc để phân tích tấn công trong Discover, Dashboard và Lens. Sai sót trong mục này có thể khiến log hiển thị không chính xác hoặc không thể phân tích.

Lệnh thực hiện

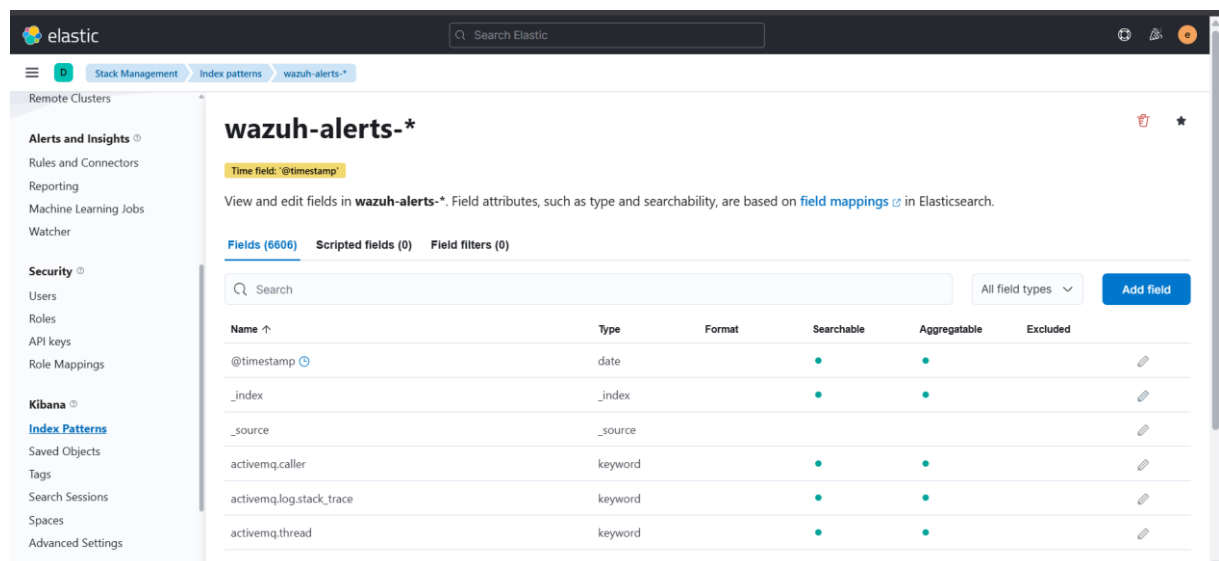
Kibana → Stack Management → Data Views → Create

Pattern: filebeat-*

Pattern: wazuh-alerts-*



Hình 18: Giao diện Data View filebeat-*



Hình 19: Giao diện View wazuh-alerts-*

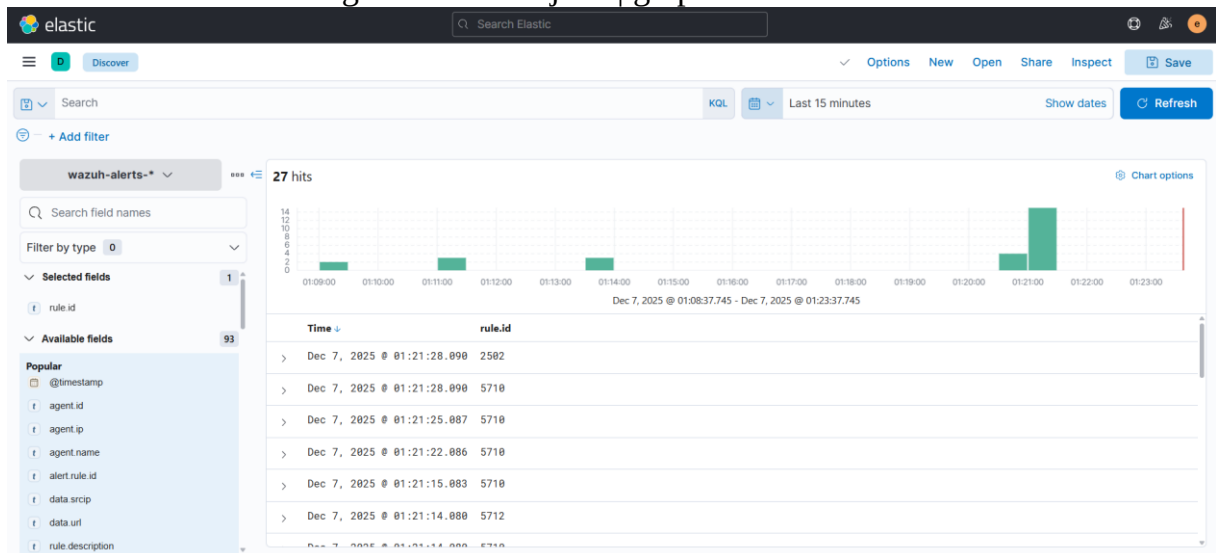
3.11. SSH Brute-force

Lý thuyết thực hiện

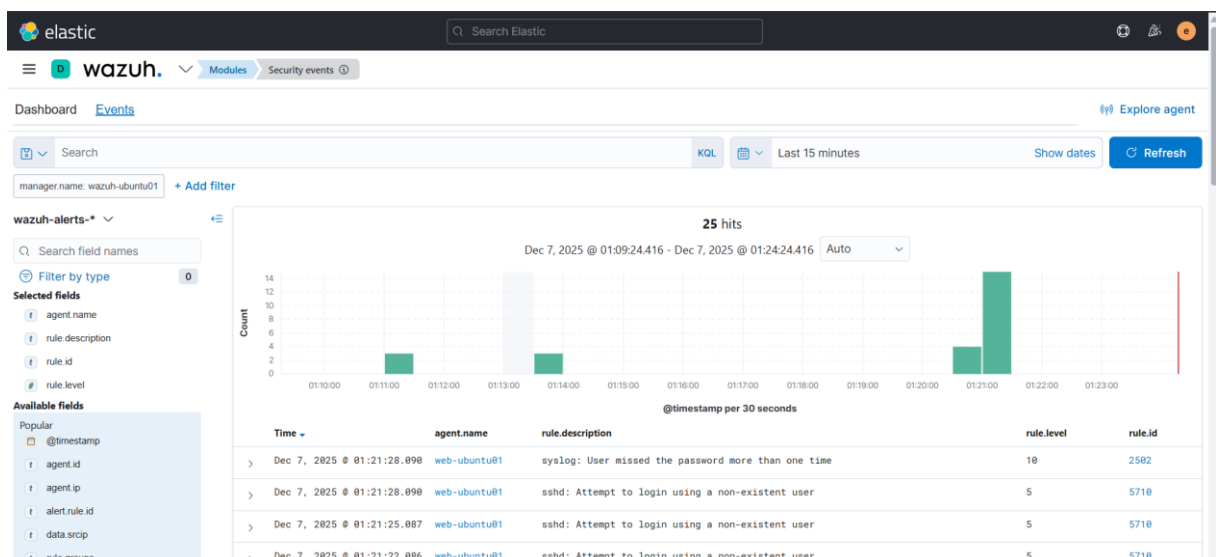
SSH brute-force là kỹ thuật phổ biến nhằm dò tìm mật khẩu đăng nhập trái phép vào hệ thống. Trong SIEM, việc phát hiện hành vi này phụ thuộc vào log auth.log và Ruleset 5712 của Wazuh. Khi số lượng đăng nhập thất bại vượt ngưỡng quy định, cảnh báo sẽ được sinh ra với mức độ nghiêm trọng cao. Dashboard giúp quan sát số lượng authentication failures theo thời gian và theo IP nguồn. Kịch bản này thể hiện khả năng phát hiện tấn công Host-based của SIEM.

Lệnh thực hiện

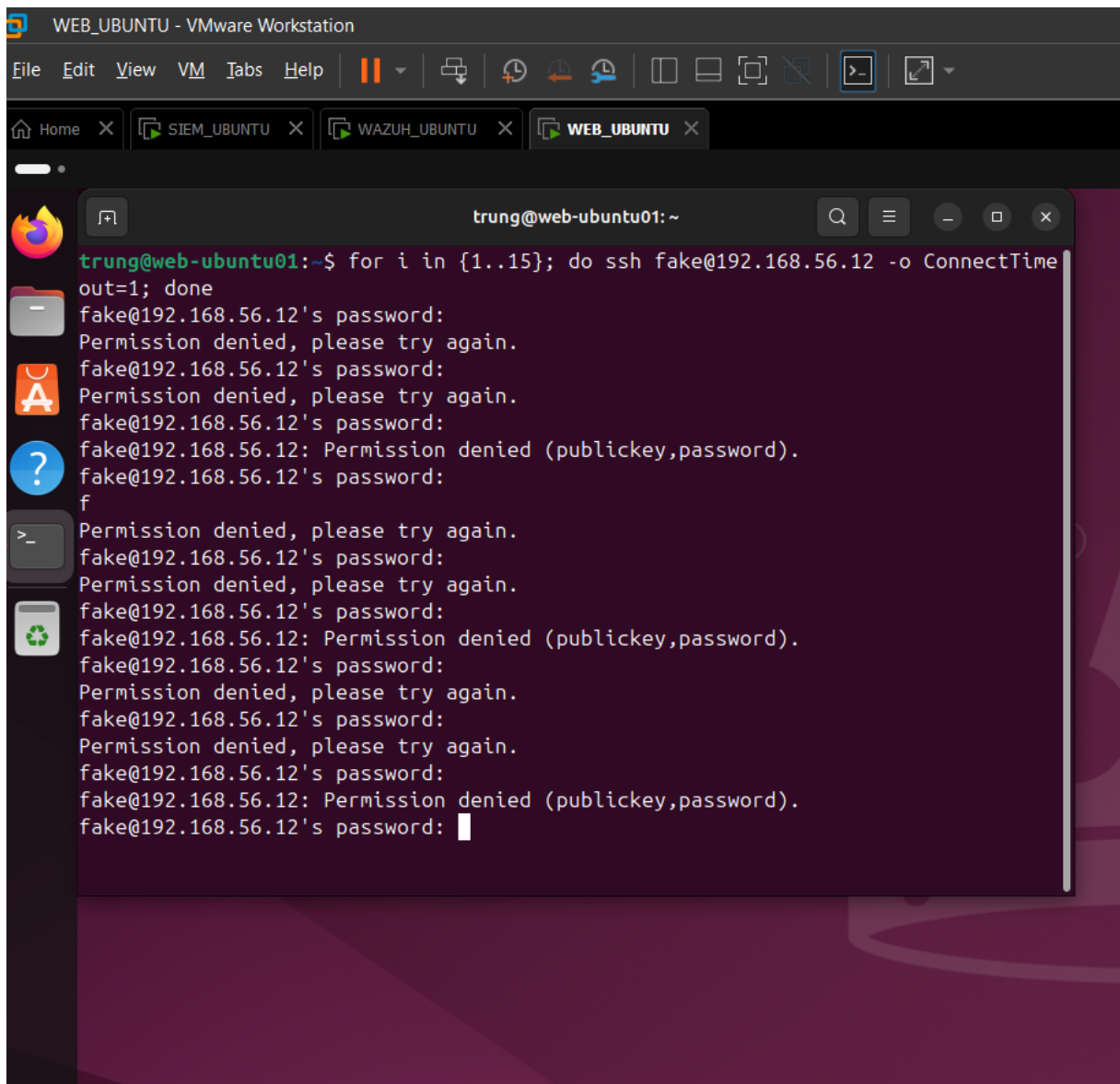
```
for i in {1..15}; do ssh fake@192.168.56.12 -o ConnectTimeout=1; done
sudo grep 'Failed password' /var/log/auth.log
sudo tail -f /var/ossec/logs/alerts/alerts.json | grep 5712
```



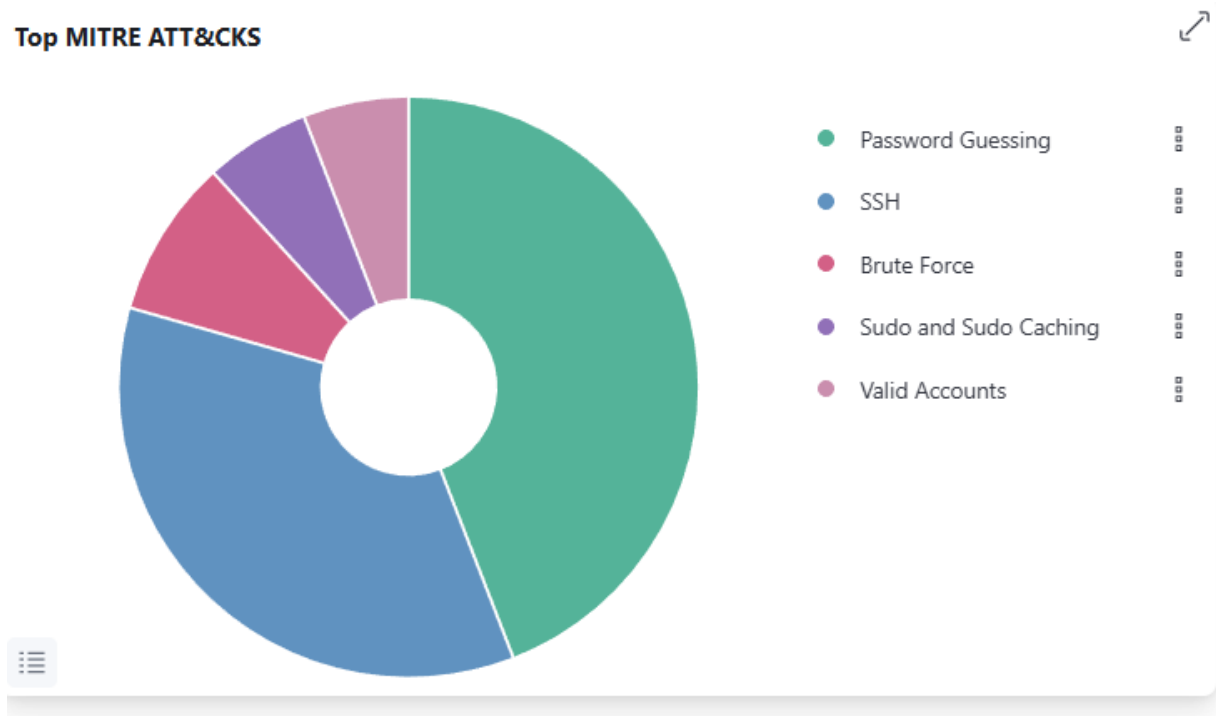
Hình 20: Cảnh báo SSH Failed trên Kibana.



Hình 21: Cảnh báo SSH Failed Attempts trên Wazuh.



Hình 22: Tấn công Brute-Force.



Hình 23: Hình ảnh dashboard cảnh báo.

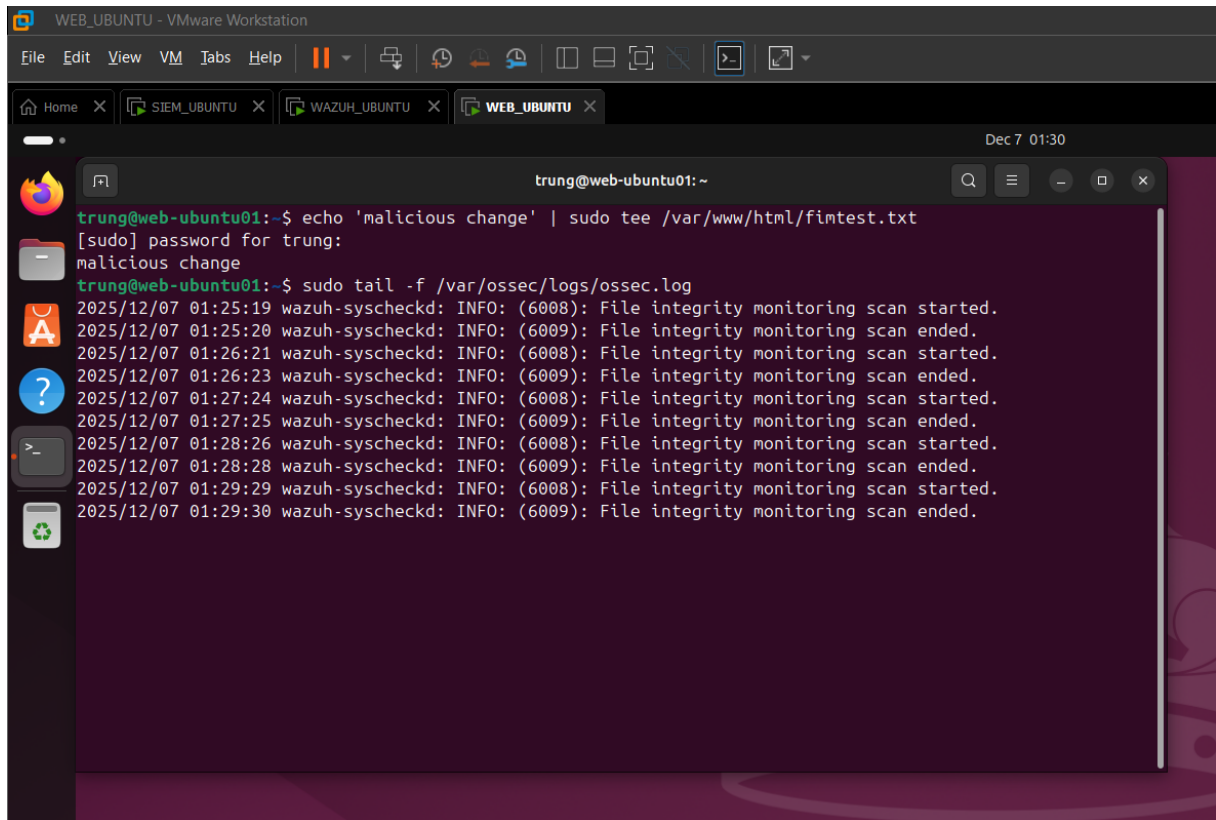
3.12. FIM – File Integrity Monitoring

Lý thuyết thực hiện

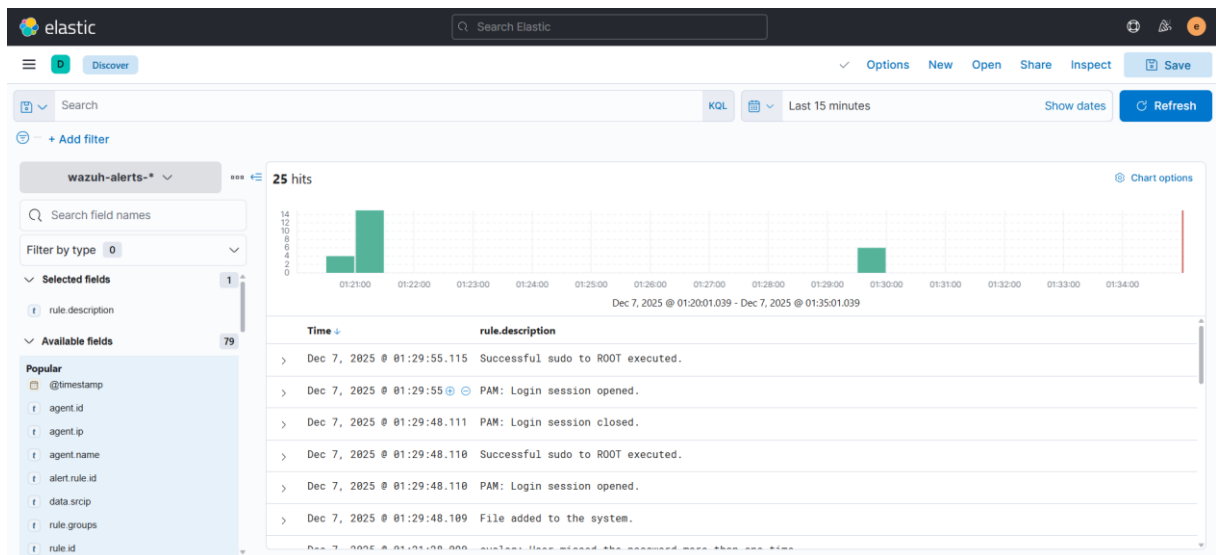
FIM theo dõi sự thay đổi các tệp tin trong hệ thống bằng cách so sánh hash và metadata qua từng chu kỳ quét. Khi một tệp bị sửa đổi hoặc thêm mới, Wazuh Agent ghi nhận sự kiện và gửi đến Manager để phân tích. Cảnh báo FIM thường có mức độ quan trọng cao, vì thay đổi trái phép tệp tin có thể là dấu hiệu của mã độc hoặc tấn công nội bộ. Dashboard FIM giúp hiển thị số lượng thay đổi file theo thời gian. Đây là một trong những tính năng mạnh nhất của Wazuh trong phát hiện tấn công không để lại dấu hiệu mạng.

Lệnh thực hiện

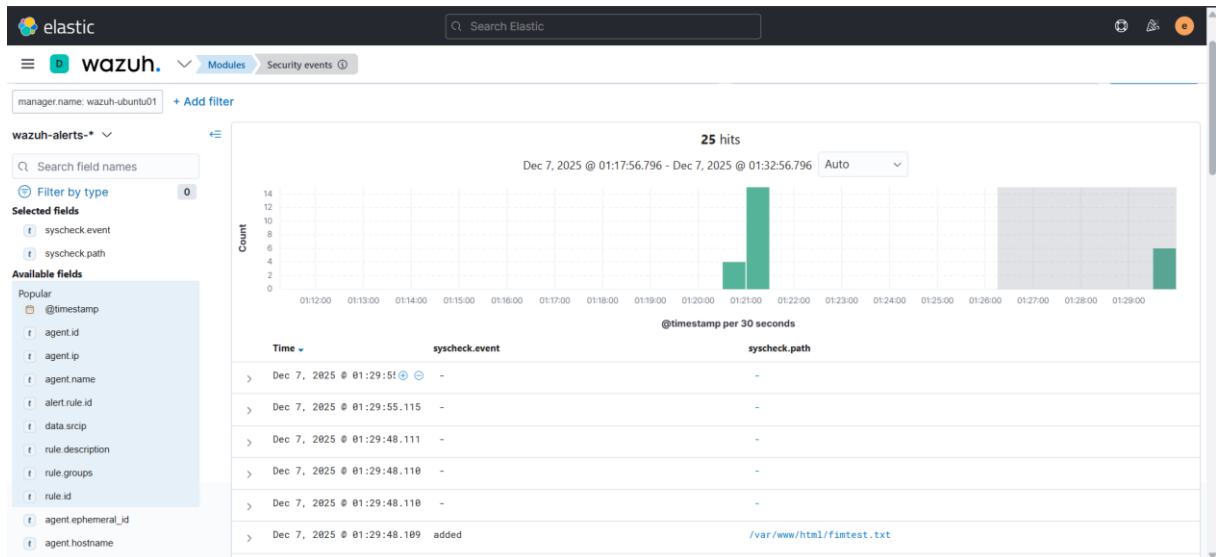
```
echo 'malicious change' | sudo tee /var/www/html/fimtest.txt
sudo tail -f /var/ossec/logs/alerts/alerts.json | grep fimtest
sudo tail -f /var/ossec/logs/ossec.log
```



Hình 24: Hình ảnh thay đổi file kích hoạt FIM



Hình 25: Giao diện cảnh báo Kibana



Hình 26: Giao diện cảnh báo Wazuh

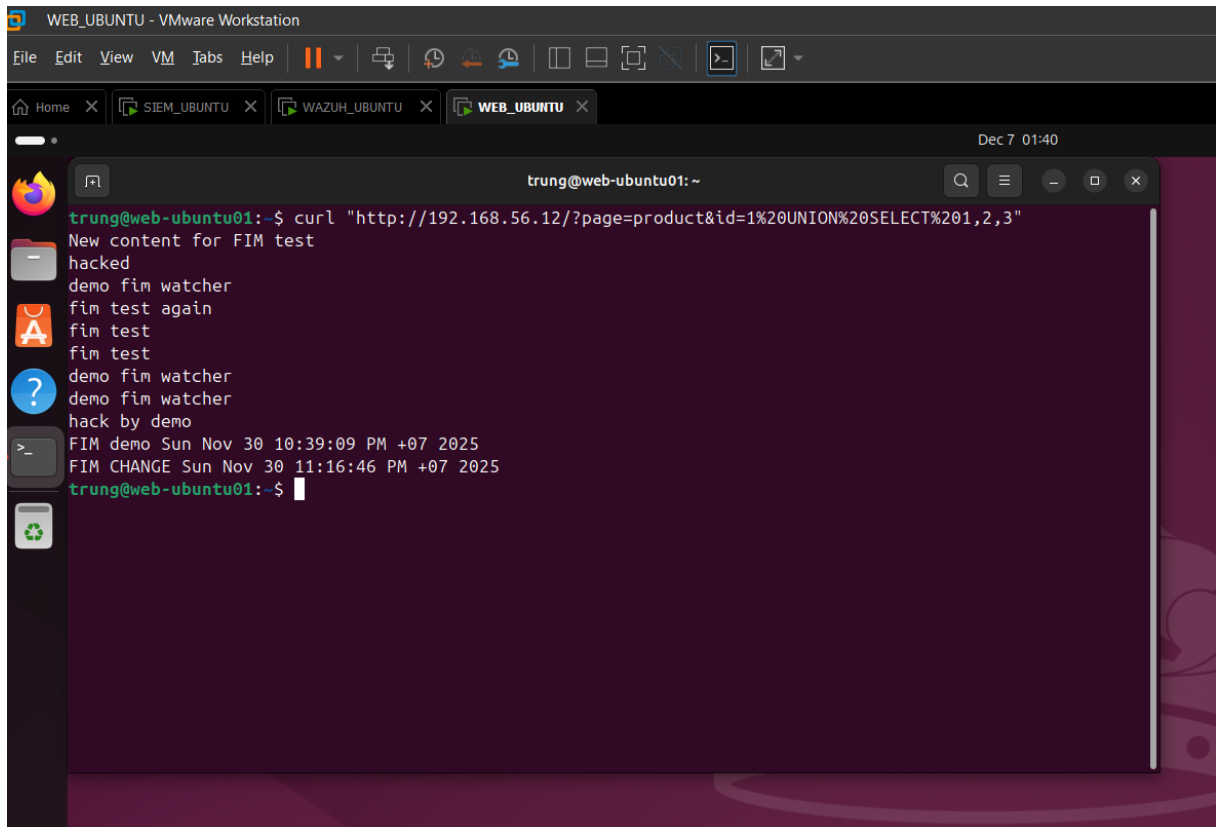
3.13. SQLi / XSS / LFI

Lý thuyết thực hiện

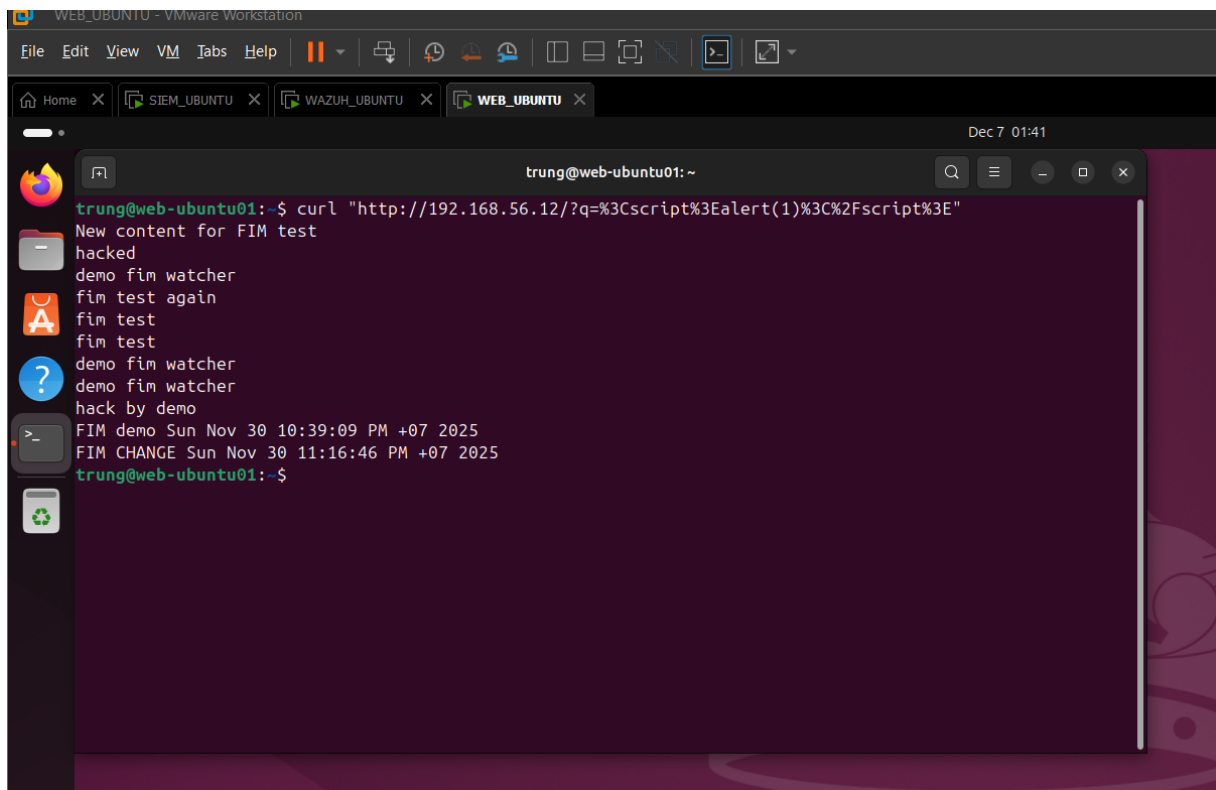
SQLi, XSS và LFI là ba loại tấn công phổ biến trong lĩnh vực an ninh web. Suricata sử dụng signatures để phát hiện payload độc hại, sau đó ghi log vào tệp eve.json. Wazuh Agent tiếp tục xử lý log này và chuyển đến Manager để phân tích mức độ nguy hiểm. Dashboard Suricata hiển thị số lượng sự kiện theo từng loại tấn công, giúp quản trị viên theo dõi thời điểm và nguồn tấn công. Kịch bản này thể hiện sự kết hợp giữa giám sát mạng và phân tích log ứng dụng trong hệ thống SIEM.

Lệnh thực hiện

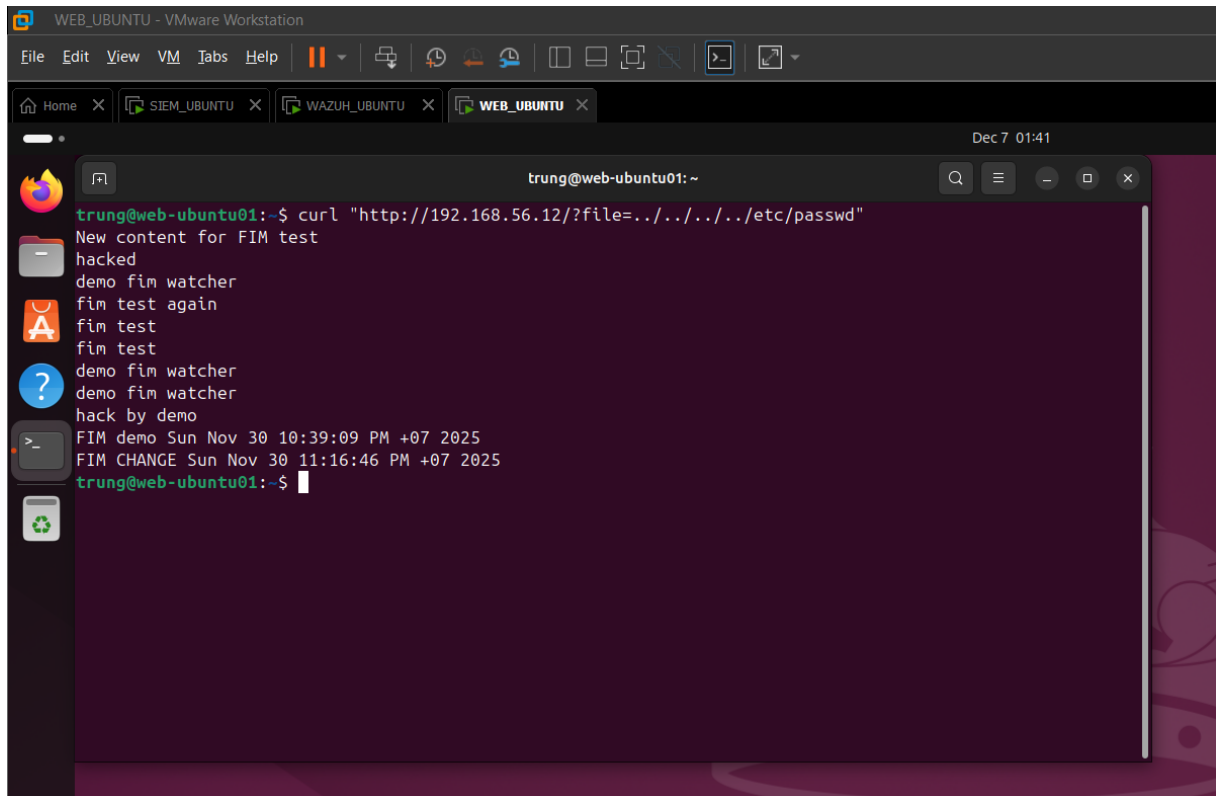
```
curl 'http://IP/?id=1 UNION SELECT 1,2,3'
curl 'http://IP/?q=<script>alert(1)</script>'
curl 'http://IP/page?file=../../etc/passwd'
```



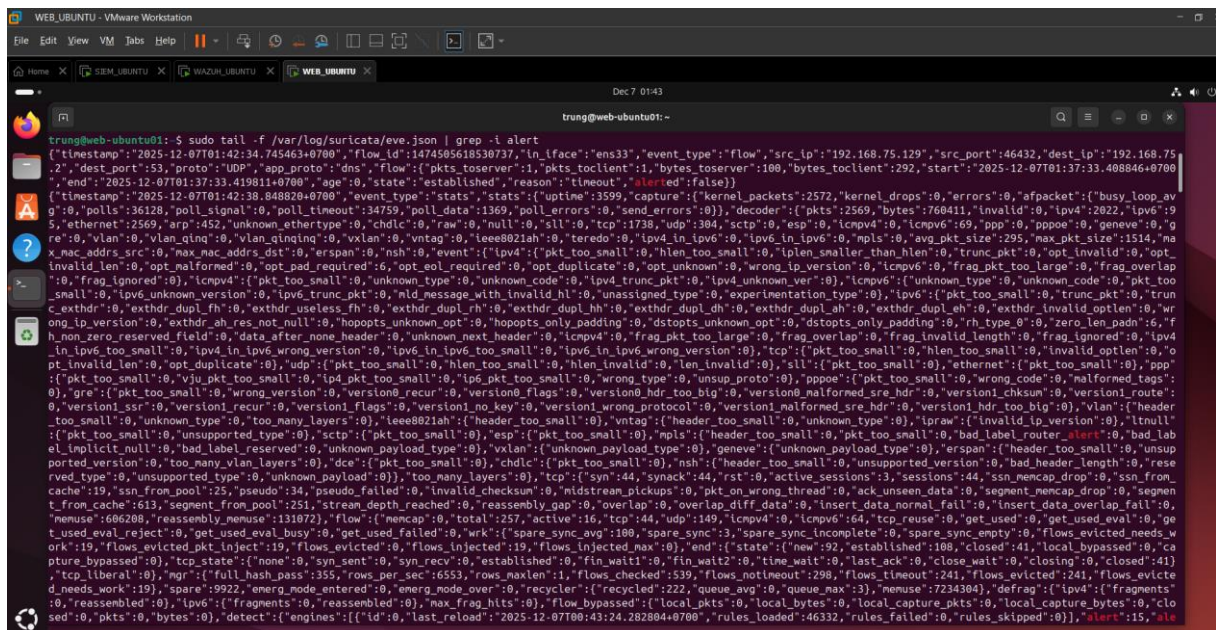
Hình 27: Hình ảnh chạy lệnh tấn công SQL Injection.



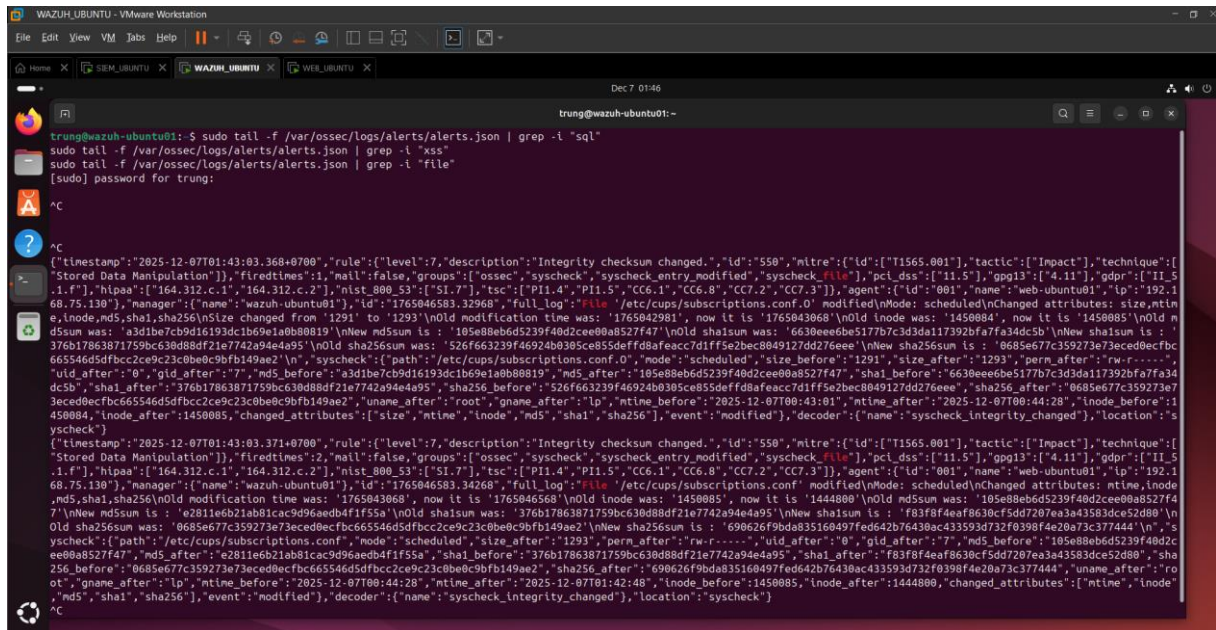
Hình 28: Hình ảnh chạy lệnh tấn công Cross-Site Scripting (XSS).



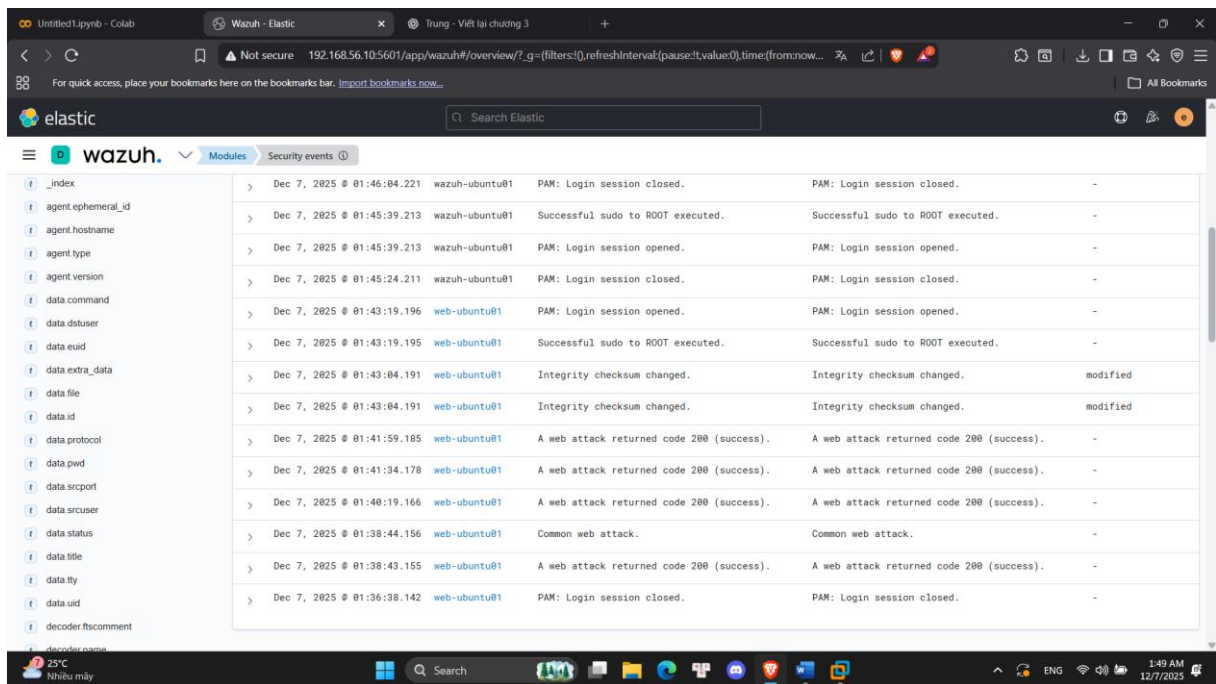
Hình 29: Hình ảnh chạy lệnh tấn công Local File Inclusion (LFI).



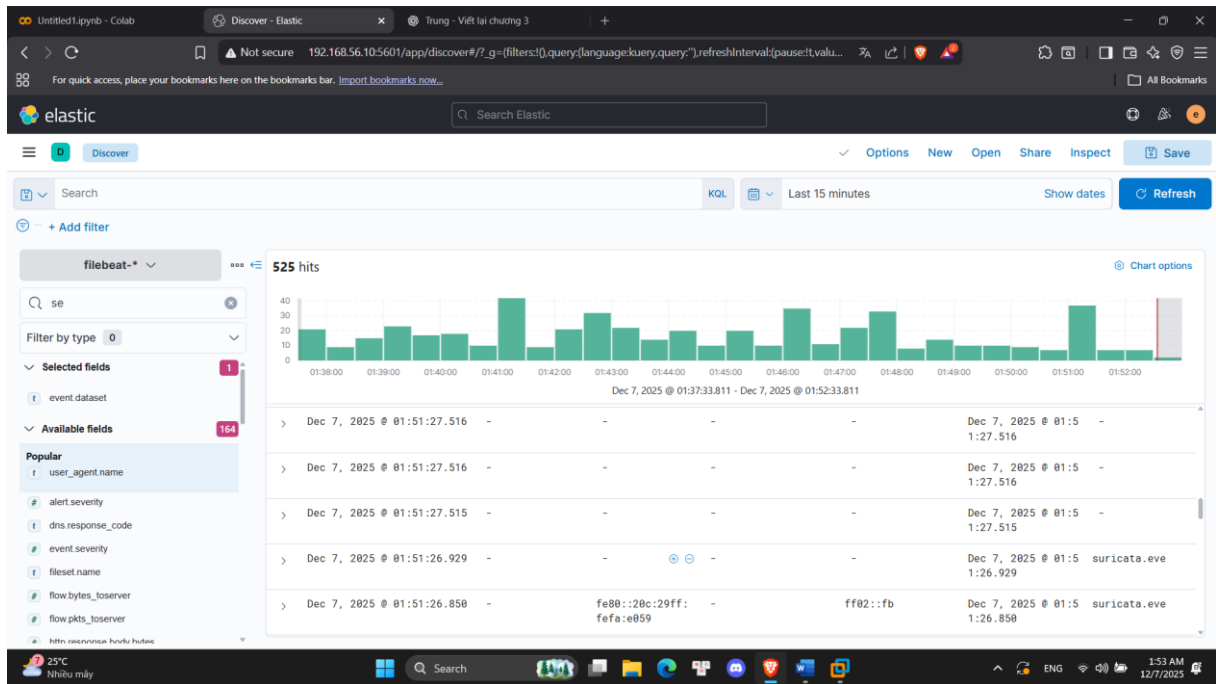
Hình 30: Hình ảnh chạy lệnh kiểm tra real-time 3 tấn công.



Hình 31: Hình ảnh Wazuh Agent trên VM3 sẽ gửi log Suricata đến Manager.

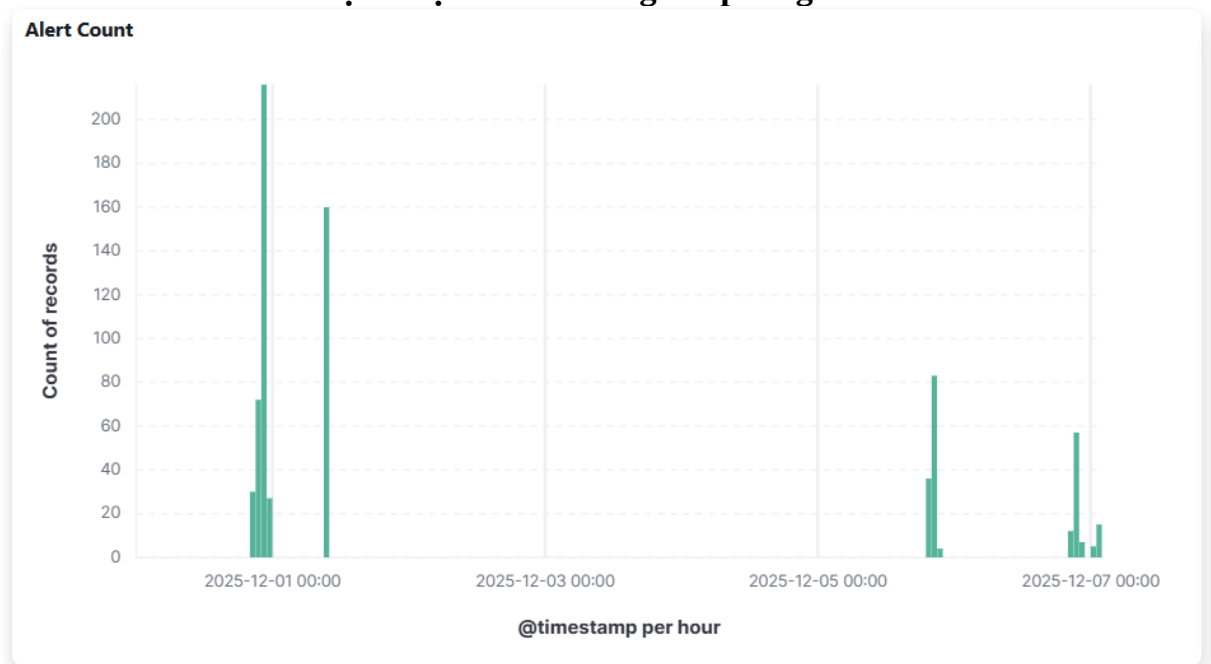


Hình 32: Hình ảnh cảnh báo tấn công trên Wazuh.

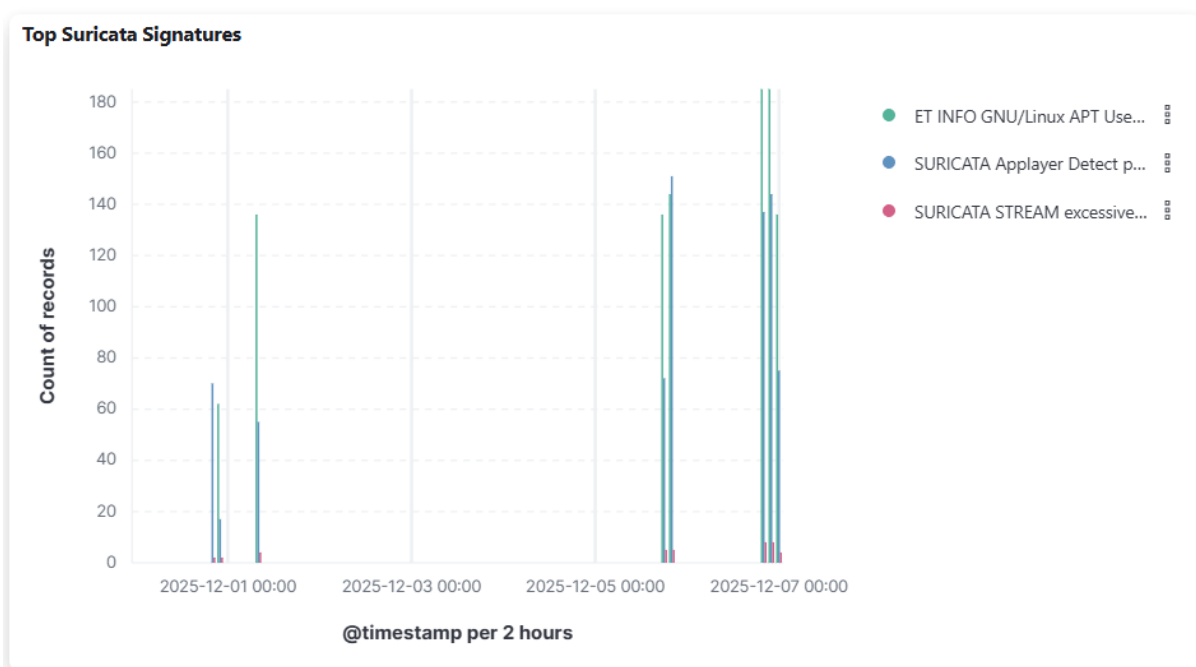


Hình 33: Hình ảnh cảnh báo tấn công trên Kibana.

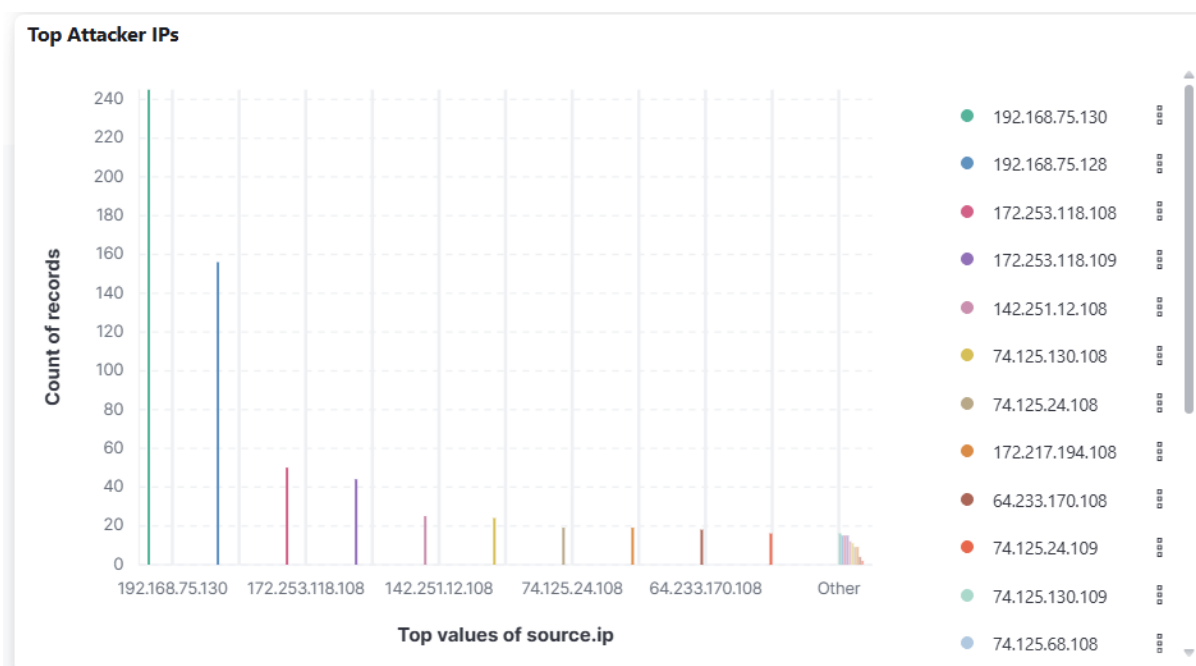
Các Dashboard hiển thị dữ liệu các tấn công mô phỏng trên kibana



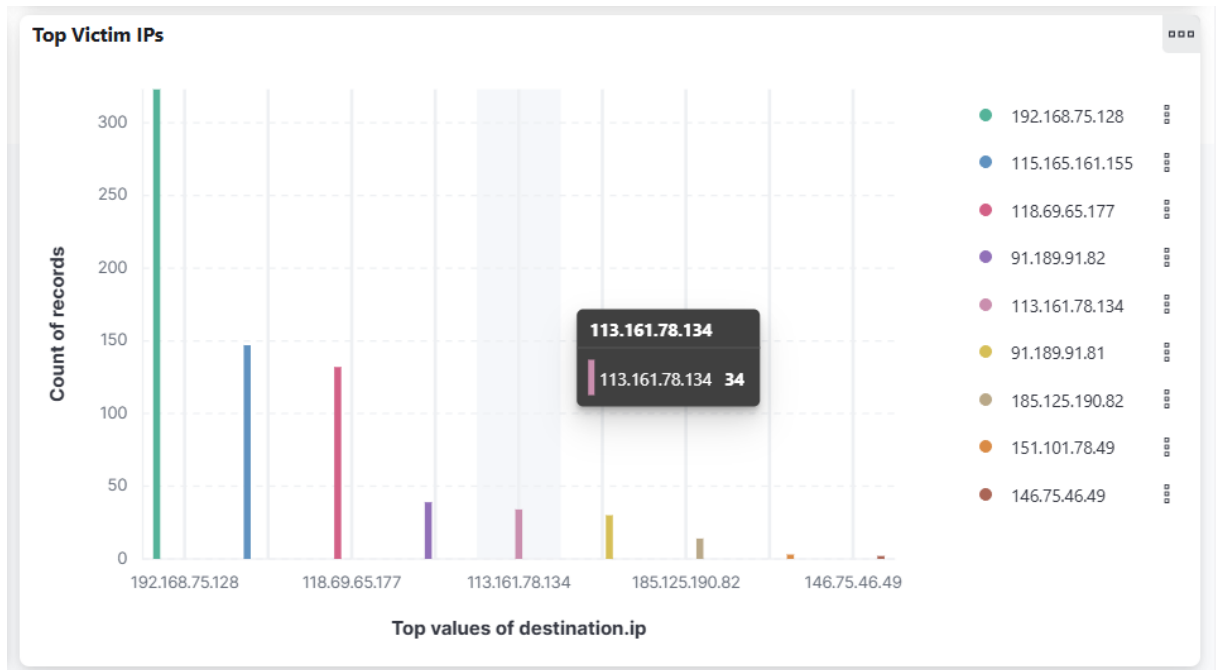
Hình 34: Hình ảnh Biểu đồ số lượng cảnh báo theo thời gian



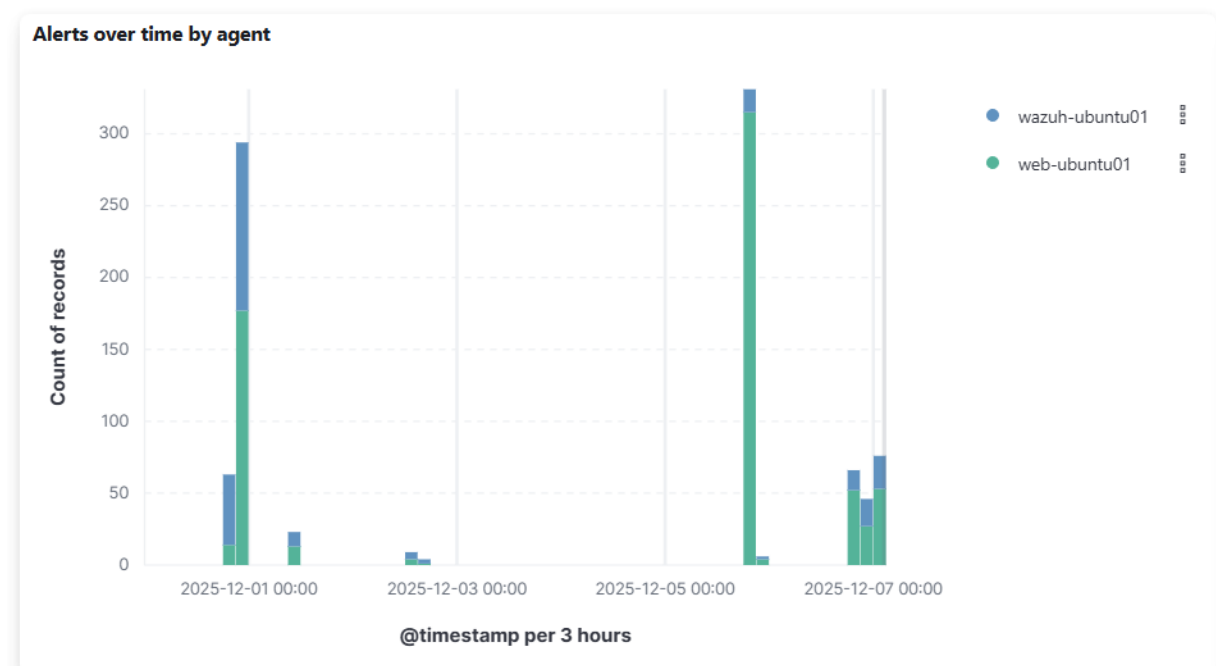
Hình 35: Hình ảnh Các chữ ký Suricata được kích hoạt nhiều nhất



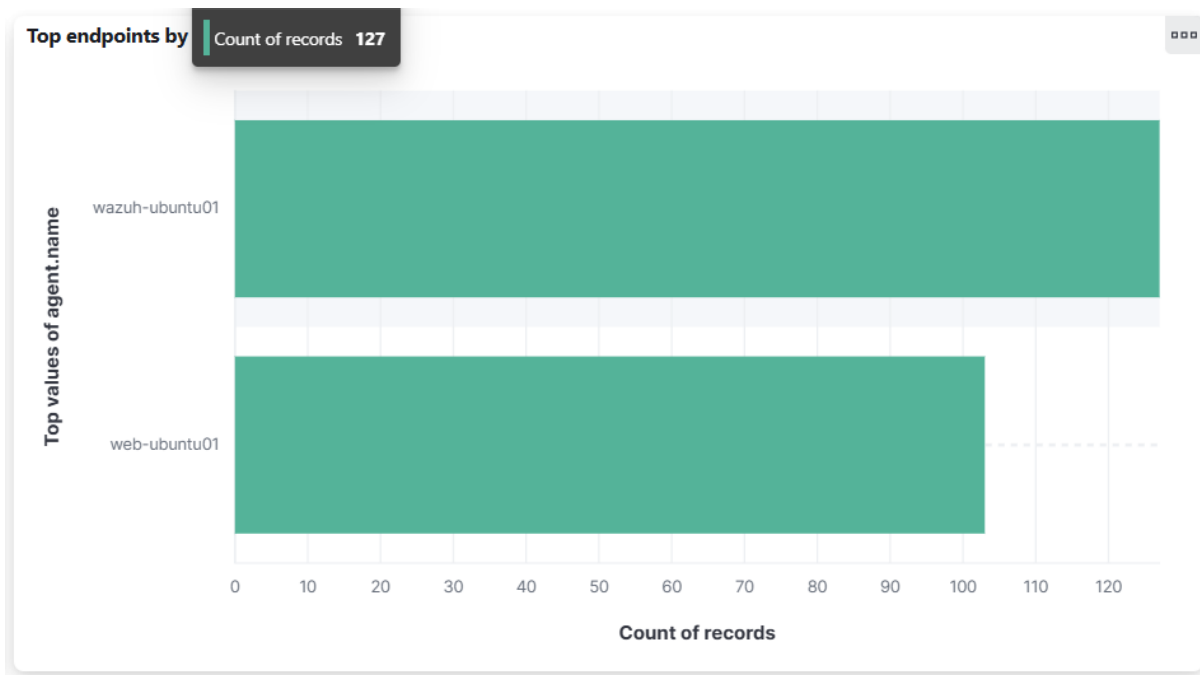
Hình 36: Hình ảnh Các địa chỉ IP tấn công nhiều nhất



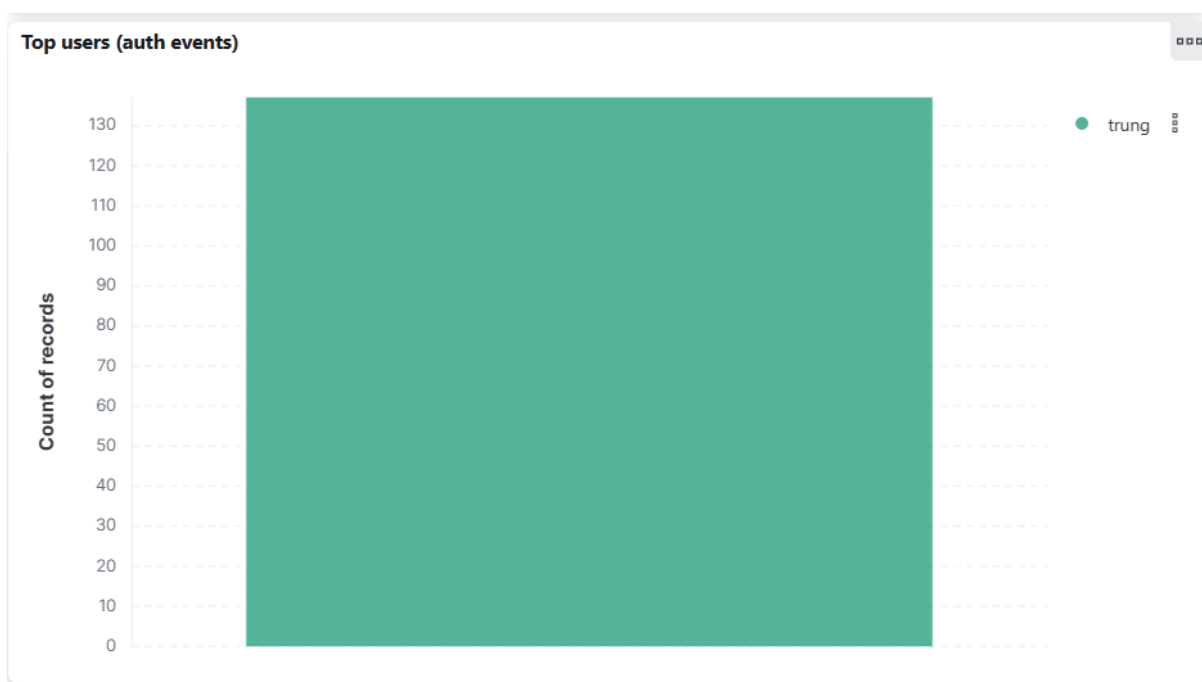
Hình 37: Hình ảnh Các địa chỉ IP mục tiêu bị tấn công



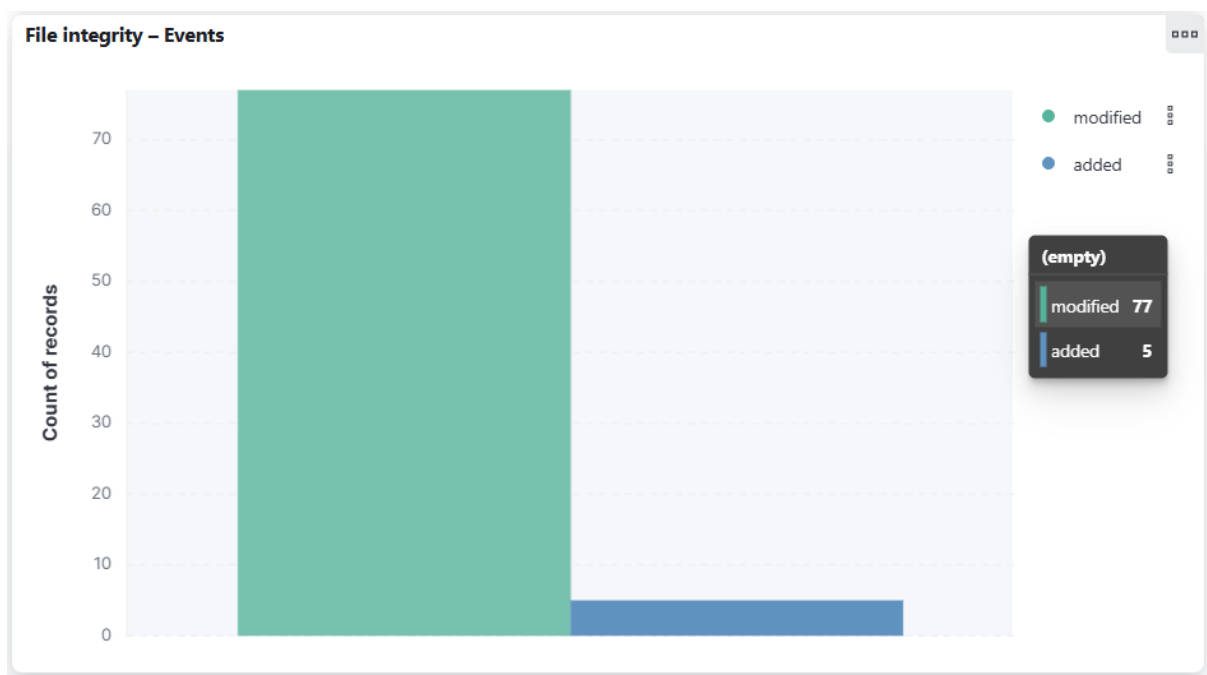
Hình 38: Hình ảnh Biểu đồ cảnh báo theo từng agent



Hình 39: Hình ảnh Biểu đồ so sánh số lượng cảnh báo theo từng endpoint



Hình 40: Hình ảnh Biểu đồ người dùng tạo nhiều sự kiện xác thực nhất



Hình 41: Hình ảnh Số lượng sự kiện thay đổi tệp tin (FIM)

File integrity – Top changed files							
web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web
1	-	3	-	1	-	3	

Hình 42: Hình ảnh Các tệp tin thay đổi nhiều nhất



Hình 43: Hình ảnh Các chiến thuật MITRE ATT&CK được kích hoạt

web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web-ubunt	web
11	26	-	-	-	19	7	

Hình 44: Hình ảnh Bảng chi tiết alert theo endpoint

3.14. Watcher Email Alert

Lý thuyết thực hiện

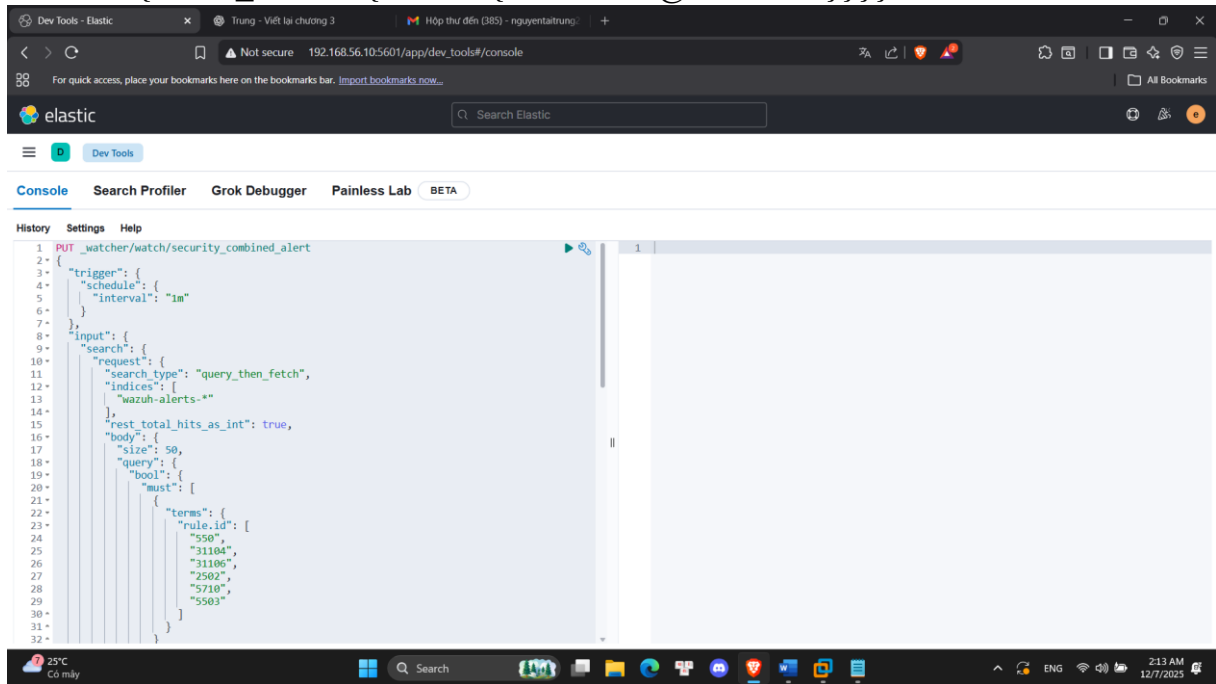
Cấu hình Watcher nhằm mục đích tự động hóa quá trình cảnh báo dựa trên các sự kiện an ninh được ghi nhận bởi Wazuh và lưu trữ trong Elasticsearch. Watcher được thiết lập chạy theo chu kỳ 1 phút, truy vấn index wazuh-alerts-* để tìm các cảnh báo có mức độ nguy hiểm cao như tấn công brute-force (5710), SQL Injection (31104), Cross-Site Scripting (31106), LFI (5503) hoặc các cảnh báo hệ thống quan trọng khác. Chỉ các sự kiện xảy ra trong 5 phút gần nhất mới được xử lý nhằm đảm bảo tính thời gian thực và

tránh trùng lặp dữ liệu. Khi số lượng alert thỏa mãn điều kiện lớn hơn 0, Watcher sẽ kích hoạt hành động gửi email đến quản trị viên kèm bảng thông tin chi tiết của từng sự kiện. Cơ chế này chứng minh khả năng tích hợp SOAR mini trong hệ thống SIEM, giúp phát hiện sớm sự cố bảo mật và hỗ trợ phản ứng nhanh chóng.

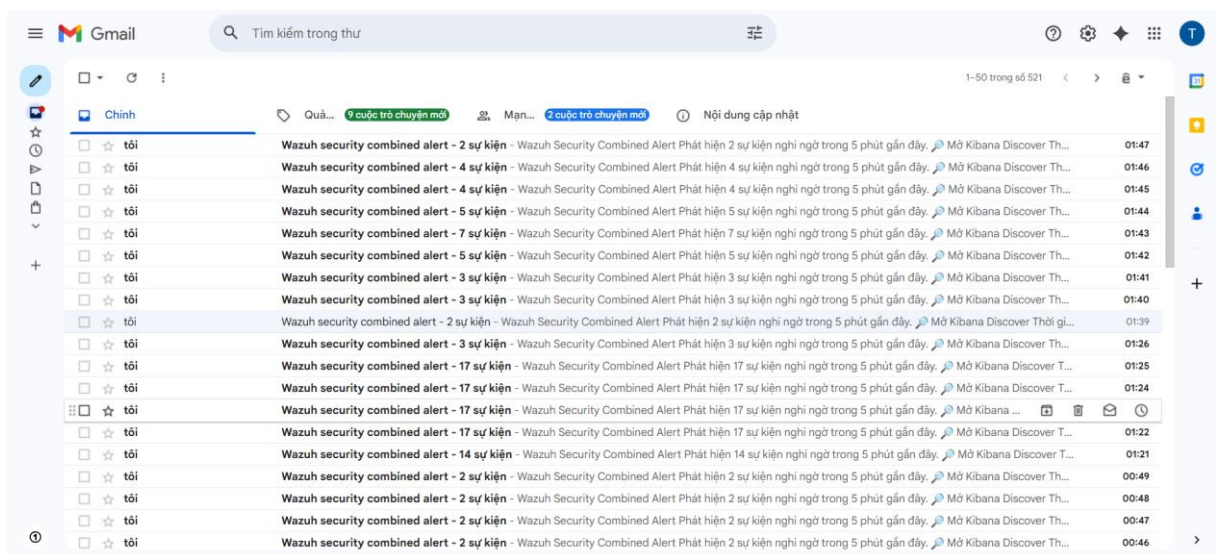
Lệnh thực hiện

PUT _watcher/watch/wazuh_alerts

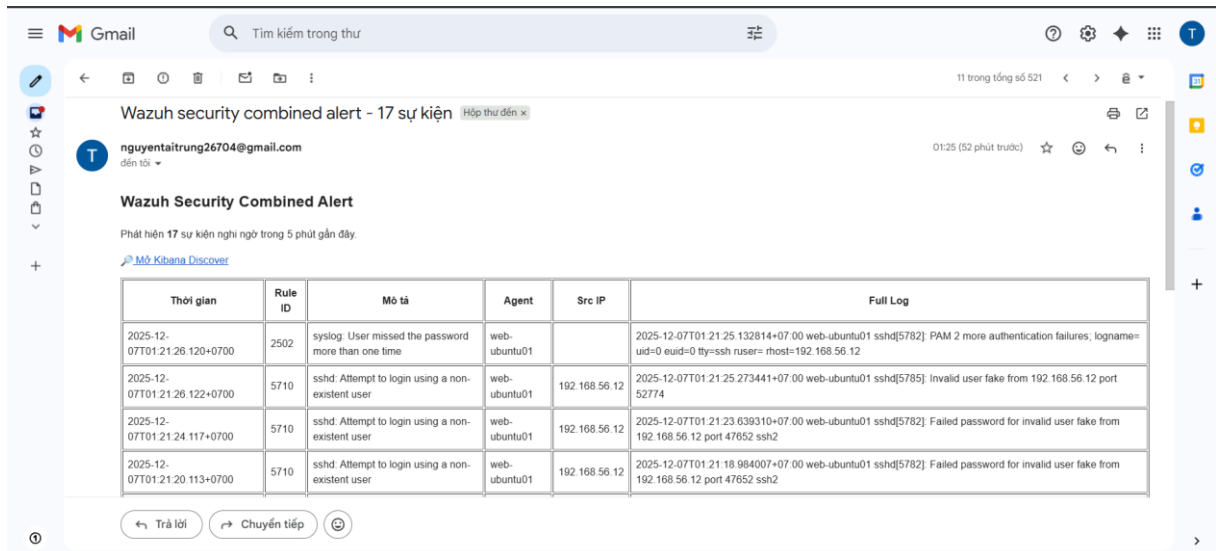
```
{ 'trigger': { 'schedule': { 'interval': '10s' } },
  'input': { 'search': { 'request': { 'indices': ['wazuh-alerts-*'] } } },
  'actions': { 'email_admin': { 'email': { 'to': 'admin@mail.com' } } } }
```



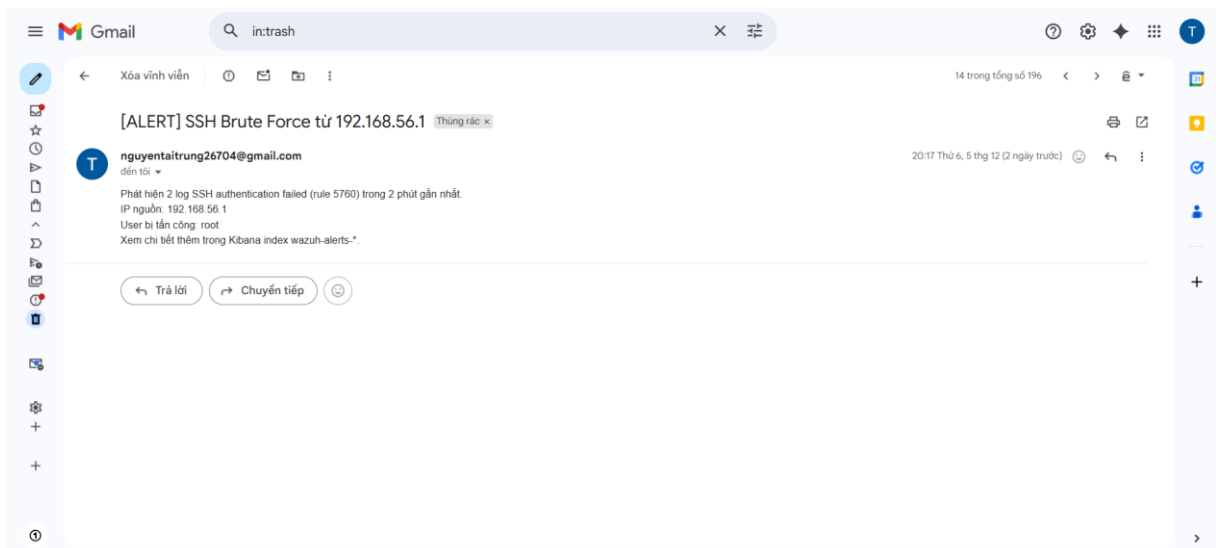
Hình 45: Cài đặt và cấu hình Email Alert gửi từ Watcher trên Dev Tools.



Hình 46: Hình ảnh Email Alert gửi từ Watcher.



Hình 47: Hình ảnh Chi tiết log được hiển thị trong email.



Hình 48: Hình ảnh phát hiện tấn công brute-force.

3.15. Kiểm tra độ trễ (Latency)

Lý thuyết thực hiện

Latency là chỉ số đo lường hiệu năng quan trọng trong hệ SIEM, cho thấy tốc độ phát hiện và phản hồi sự kiện bảo mật. Nó được tính bằng chênh lệch thời gian giữa lúc log gốc được ghi và lúc alert xuất hiện trong Elasticsearch. Độ trễ thấp cho thấy pipeline hoạt động hiệu quả và không bị tắc nghẽn. Trong mô hình Direct Ingest, độ trễ thường thấp hơn do không sử dụng Logstash. Đồ án yêu cầu $FIM \leq 5s$ và $SSH\ brute-force \leq 10s$.

Lệnh thực hiện

```
curl -k -u elastic:pw 'https://192.168.56.10:9200/wazuh-alerts-*/_search?pretty'
grep timestamp
compare event.original vs @timestamp
```


Lý thuyết thực hiện

Dataset cho mô hình AI được xây dựng dựa trên các log tạo ra từ Wazuh, Suricata và Nginx, sau đó được làm sạch và chuẩn hóa. Quá trình tạo dataset bao gồm việc chọn lọc các trường quan trọng như IP nguồn, HTTP method, đường dẫn URL, status code, signature và rule.id. Tiếp theo là gán nhãn các sự kiện (normal, brute-force, SQLi, XSS, LFI...) dựa trên quy tắc hoặc nguồn sinh cảnh báo. Dataset cần được xử lý mất cân bằng (imbalanced data) và trích xuất thêm đặc trưng (feature engineering) để nâng cao khả năng học của mô hình. Một dataset chất lượng cao giúp AI phân loại chính xác hành vi tấn công, giảm nhầm lẫn và tăng độ tin cậy của toàn bộ hệ thống SIEM.

Timestamp	agent.id	agent.ip	agent.name	rule.id	rule.signature	attack.type	data.source	data.url	event.data	http.method	attack.label	message	rule.id	source.ip	check.event	check.path	test.case	url.path	agent.name
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5501						NORMAL
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5502						NORMAL
Nov 27, 2023	1	web-ubuntu01				PRIV_ESC_SUDO						Successful sudo to RC	5402						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5501						NORMAL
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5502						NORMAL
Nov 27, 2023	1	web-ubuntu01				PRIV_ESC_SUDO						Successful sudo to RC	5402						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				PRIV_ESC_SUDO						Successful sudo to RC	5402						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5502						NORMAL
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5501						NORMAL
Nov 27, 2023	1	web-ubuntu01				LFI	192.168.51	/index.php?page=../../../../etc/p				Common web attack.	31104						TC02_WEB_ATTACK_LFI
Nov 27, 2023	1	web-ubuntu01				WEB_ATTACK_192.168.51	/index.php?page=../../../../etc/p					A web attack returne	31106						TC02_WEB_ATTACK
Nov 27, 2023	1	web-ubuntu01				APPARMOR_DENIED						Apparmor DENIED	52002						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				APPARMOR_DENIED						Apparmor DENIED	52002						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				WEB_ATTACK_192.168.51	/index.php?id=1					Web server 400 error	31101						TC02_WEB_ATTACK
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_FORCE						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				BENIGN	192.168.56.12					syslog: User missed th	2502						NORMAL
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						PAM: User login fail	5503						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						PAM: User login fail	5503						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_FORCE						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				BENIGN	192.168.56.12					syslog: User missed th	2502						NORMAL
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						ssh: authentication f	5760						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				SSH_BRUTE_192.168.56.12						PAM: User login fail	5503						TC01_SSH_BRUTE
Nov 27, 2023	1	web-ubuntu01				PRIV_ESC_SUDO						Successful sudo to RC	5402						TC05_FIM
Nov 27, 2023	1	web-ubuntu01				BENIGN						PAM: Login session ok	5501						NORMAL

Hình 50: Dataset raw sau khi làm sạch và gán nhãn

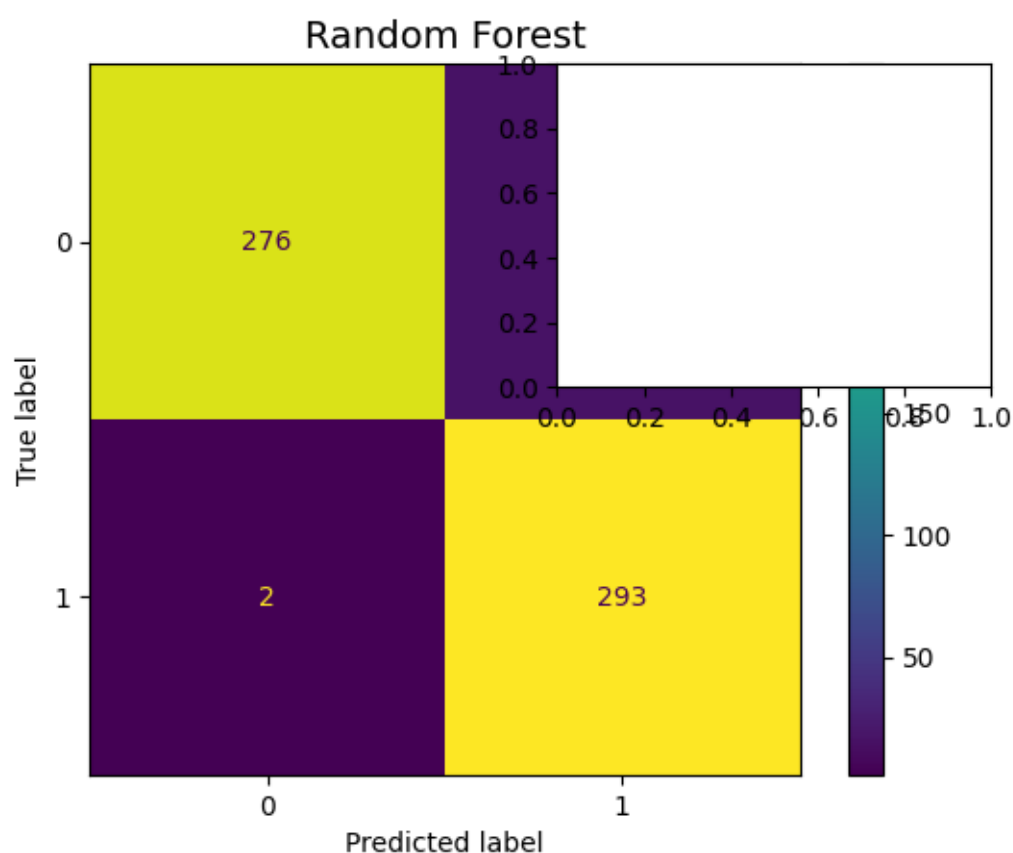
test.case	attack.type	is_attack	wazuh.alert	TP	FP	FN	Precision	Recall	F1
TC01_SSH_BRUTE	SSH_BRUTE_FORCE	28	28	28	0	0	1	1	1
TC02_WEB_ATTACK	WEB_ATTACK	2	2	2	0	0	1	1	1
TC02_WEB_ATTACK_LFI	LFI	7	7	7	0	0	1	1	1
TC02_WEB_ATTACK_SQU	SQLi	2	2	2	0	0	1	1	1
TC02_WEB_ATTACK_XSS	XSS	1	1	1	0	0	1	1	1
TC04_SURICATA	SURICATA_ALERT	1413	0	0	0	1413	0	0	0
TC05_FIM	PRIV_ESC_SUDO	20	20	20	0	0	1	1	1

Hình 51: Các chỉ số *wazuh_metrics* đã được tính toán và đánh giá

3.18. Huấn luyện mô hình Random Forest

Lý thuyết thực hiện

Random Forest là thuật toán thuộc nhóm học máy tổ hợp (Ensemble Learning), hoạt động bằng cách xây dựng nhiều cây quyết định và biểu quyết kết quả. Thuật toán này có khả năng xử lý dữ liệu phi tuyến tính, chống overfitting tốt và phù hợp với việc phân loại log an ninh mạng có tính biến động cao. Trong hệ thống SIEM, Random Forest giúp phân biệt hành vi bình thường và tấn công dựa trên nhiều đặc trưng từ dataset. Mô hình này thường là baseline trong các nghiên cứu về phát hiện tấn công vì dễ triển khai và có tính ổn định cao.



Hình 52: Confusion Matrix của Random Forest

```

from sklearn.ensemble import RandomForestClassifier
from sklearn.metrics import classification_report, confusion_matrix

rf = RandomForestClassifier(
    n_estimators=500,
    max_depth=20,
    class_weight={0:1, 1:4},
    random_state=42,
    n_jobs=-1
)

rf.fit(X_train, y_train)
pred_rf = rf.predict(X_test)

print("=== Random Forest ===")
print(confusion_matrix(y_test, pred_rf))
print(classification_report(y_test, pred_rf, digits=4))

```

```

*** === Random Forest ===
[[276  16]
 [   2 293]]

```

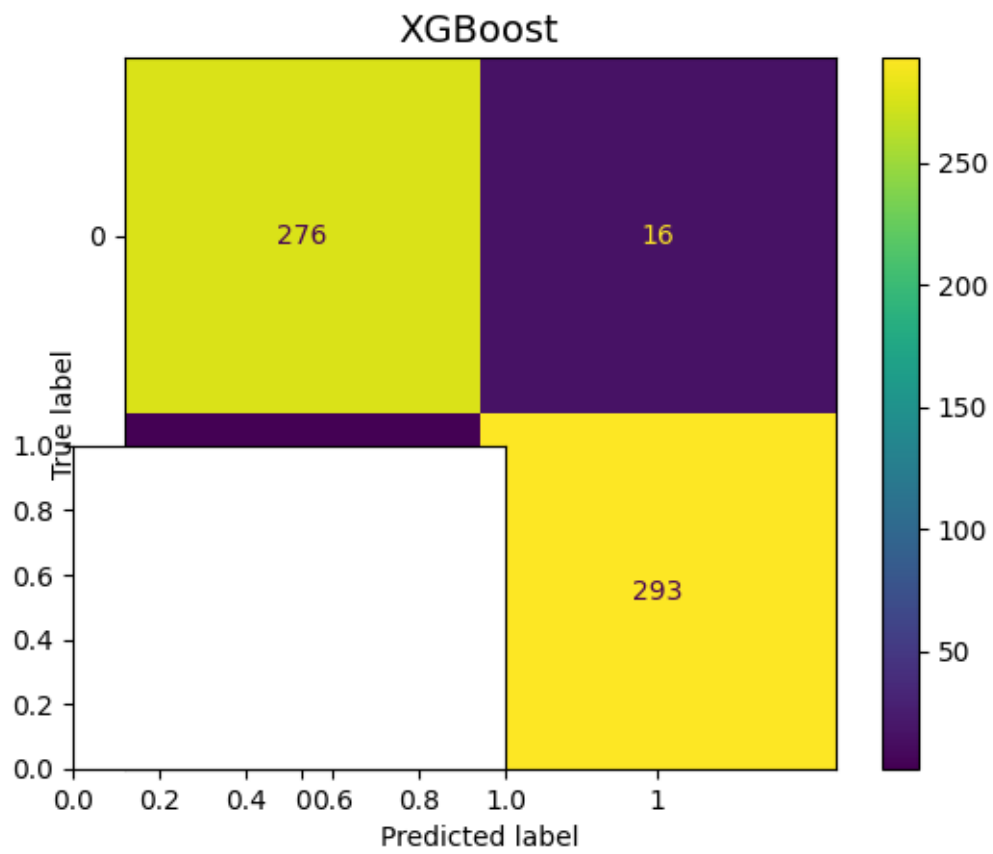
	precision	recall	f1-score	support
0	0.9928	0.9452	0.9684	292
1	0.9482	0.9932	0.9702	295
accuracy			0.9693	587
macro avg	0.9705	0.9692	0.9693	587
weighted avg	0.9704	0.9693	0.9693	587

Hình 53: Precision/Recall của Random Forest

3.19. Huấn luyện mô hình XGBoost

Lý thuyết thực hiện

XGBoost là thuật toán tăng cường dốc (Gradient Boosting) tối ưu hiệu năng, được thiết kế để xử lý tập dữ liệu lớn và phức tạp. Thuật toán này học dựa trên việc kết hợp nhiều mô hình yếu (weak learners) để tạo thành một mô hình mạnh hơn. XGBoost đặc biệt hiệu quả trong phát hiện tấn công vì có khả năng bắt được các mẫu (pattern) tinh vi, giúp giảm tỷ lệ bỏ sót tấn công (False Negative). Trong mô hình SIEM, XGBoost thường đạt Recall cao, phù hợp cho mục tiêu không bỏ sót sự kiện nguy hiểm.



Hình 54: Confusion Matrix của XGBoost

```

import xgboost as xgb

xgb_model = xgb.XGBClassifier(
    n_estimators=600,
    max_depth=10,
    learning_rate=0.08,
    subsample=0.9,
    colsample_bytree=0.9,
    scale_pos_weight=4,
    eval_metric="logloss",
    random_state=42
)

xgb_model.fit(X_train, y_train)
pred_xgb = xgb_model.predict(X_test)

print("=== XGBoost ===")
print(confusion_matrix(y_test, pred_xgb))
print(classification_report(y_test, pred_xgb, digits=4))

```

```

... === XGBoost ===
[[276 16]
 [ 2 293]]

```

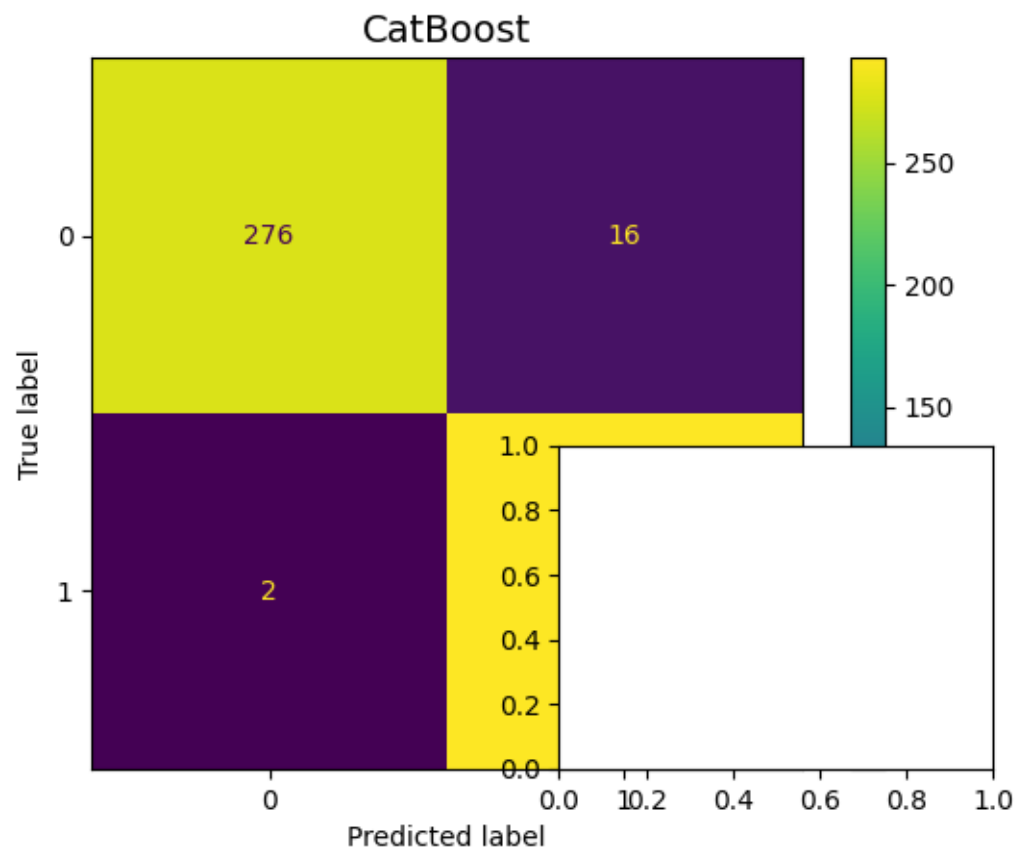
	precision	recall	f1-score	support
0	0.9928	0.9452	0.9684	292
1	0.9482	0.9932	0.9702	295
accuracy			0.9693	587
macro avg	0.9705	0.9692	0.9693	587
weighted avg	0.9704	0.9693	0.9693	587

Hình 55: Precision/Recall của XGBoost

3.20. Huấn luyện mô hình CatBoost

Lý thuyết thực hiện

CatBoost là thuật toán boosting đặc biệt hiệu quả với dữ liệu chứa nhiều đặc trưng dạng chuỗi (categorical features), vốn xuất hiện nhiều trong log HTTP và log tấn công web. Mô hình này giảm thiểu overfitting, tự động mã hóa các feature dạng text, không yêu cầu one-hot encoding và đạt độ chính xác cao. Với dataset log, CatBoost thường cho Precision cao nhất vì phân biệt tốt hành vi hợp lệ và tấn công, giảm rõ rệt số lượng cảnh báo sai.



Hình 56: Confusion Matrix của CatBoost

```

from catboost import CatBoostClassifier

cat = CatBoostClassifier(
    iterations=900,
    depth=10,
    learning_rate=0.05,
    loss_function="Logloss",
    verbose=False,
    random_state=42
)

cat.fit(X_train, y_train)
pred_cat = cat.predict(X_test)

print("=== CatBoost ===")
print(confusion_matrix(y_test, pred_cat))
print(classification_report(y_test, pred_cat, digits=4))

```

```

=== CatBoost ===
[[276  16]
 [  2 293]]

```

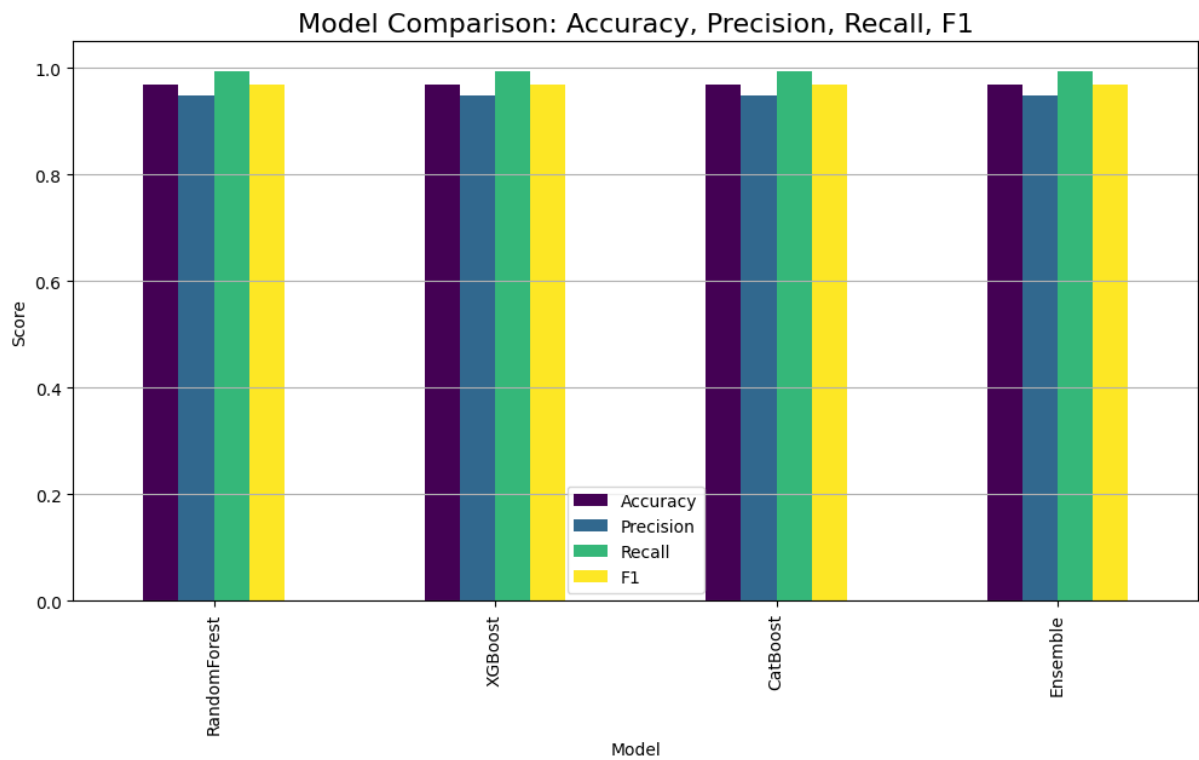
	precision	recall	f1-score	support
0	0.9928	0.9452	0.9684	292
1	0.9482	0.9932	0.9702	295
accuracy			0.9693	587
macro avg	0.9705	0.9692	0.9693	587
weighted avg	0.9704	0.9693	0.9693	587

Hình 57: Precision/Recall CatBoost

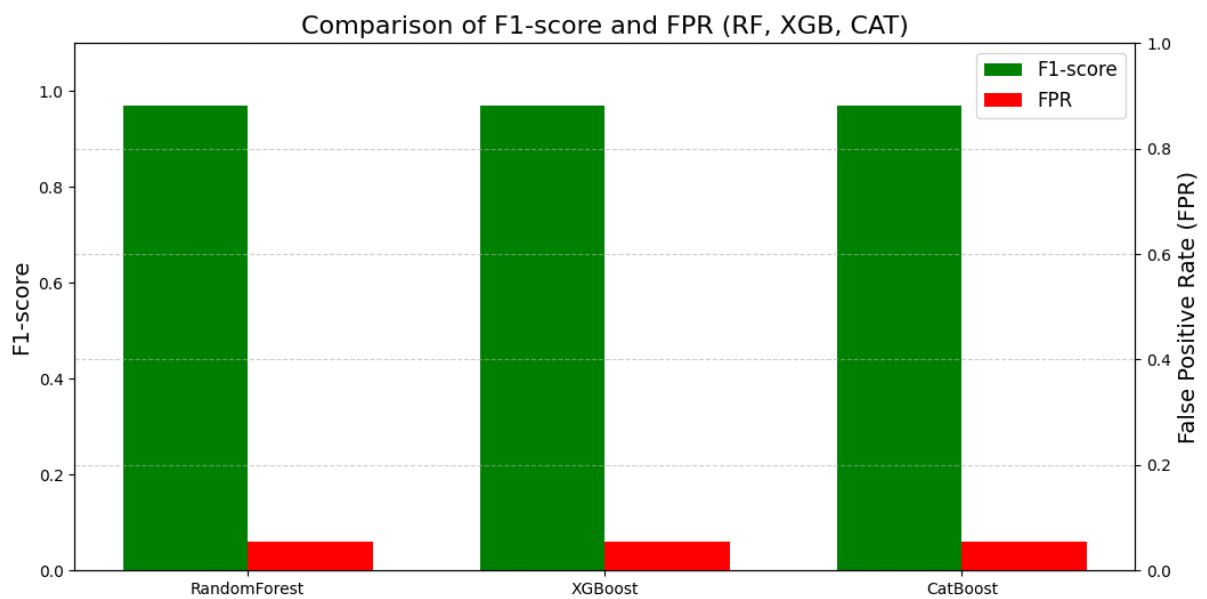
3.21. So sánh ba mô hình Machine Learning

Lý thuyết thực hiện

Việc so sánh mô hình cho phép đánh giá toàn diện khả năng phát hiện tấn công dựa trên các chỉ số như Precision, Recall, F1-score và False Positive Rate. Random Forest cho hiệu năng ổn định, XGBoost có Recall cao giúp giảm bỏ sót tấn công, còn CatBoost đạt Precision vượt trội giúp giảm cảnh báo giả. Ba mô hình bổ sung cho nhau, cung cấp góc nhìn toàn diện trong phân tích hành vi. Kết quả so sánh là cơ sở quan trọng để lựa chọn mô hình triển khai thực tế trong môi trường SIEM.



Hình 58: Biểu đồ so sánh Precision/Recall của 3 mô hình



Hình 59: Biểu đồ tổng hợp F1-score và FPR

CHƯƠNG 4: KẾT LUẬN THỰC NGHIỆM

Chương 3 đã trình bày toàn bộ quy trình triển khai, cấu hình, mô phỏng tấn công, thu thập dữ liệu và đánh giá hệ thống SIEM dựa trên Wazuh kết hợp ELK Stack theo kiến trúc Direct Ingest. Từ việc xây dựng hạ tầng mạng, cài đặt các thành phần chính (Elasticsearch, Kibana, Wazuh Manager, Agent, Suricata, Nginx), đến việc mô phỏng 5 kịch bản tấn công thực tế và phân tích cảnh báo trên Dashboard, chương này đã chứng minh rõ ràng khả năng phát hiện đa lớp (Host-based + Network-based) của hệ thống. Kết quả thực nghiệm cho thấy:

Pipeline log hoạt động ổn định và có độ trễ thấp. Qua phép đo Latency, độ trễ trung bình dao động từ 5–10 giây, đáp ứng yêu cầu thời gian thực của SIEM, đặc biệt với các sự kiện FIM và SSH brute-force. Điều này khẳng định hiệu quả của kiến trúc Direct Ingest khi loại bỏ Logstash, giảm tải xử lý trung gian.

Khả năng phát hiện tấn công rõ ràng và đầy đủ. Wazuh phát hiện tốt các hành vi liên quan đến xác thực (SSH brute-force, sudo, thay đổi file), trong khi Suricata nhận diện chính xác các tấn công Web như SQLi, XSS và LFI. Các dashboard trong Kibana cung cấp góc nhìn trực quan về nguồn tấn công, mức độ nghiêm trọng, địa chỉ IP, user liên quan, giúp quản trị viên dễ dàng theo dõi và điều tra.

Hệ thống cảnh báo nâng cao qua Watcher hoạt động hiệu quả. Watcher truy vấn dữ liệu wazuh-alerts-* theo chu kỳ 1 phút và gửi email cảnh báo tự động khi phát hiện sự kiện nghiêm trọng. Điều này tái hiện chức năng SOAR mini trong thực tế, chứng minh hệ thống có thể mở rộng vào hướng phản ứng tự động.

Tuning rule và signatures giúp tăng độ chính xác. Việc tinh chỉnh ngưỡng brute-force, lọc các sự kiện nhiễu và tối ưu signatures Suricata nhằm mục tiêu giảm false positive, đồng thời giữ nguyên độ nhạy của hệ thống. Đây là bước chuẩn bị quan trọng trước khi áp dụng AI/ML.

Dataset phục vụ mô hình AI được xây dựng hoàn chỉnh. Từ log Wazuh – Suricata – Nginx, nhóm đã làm sạch dữ liệu, gán nhãn sự kiện và tính toán thêm các đặc trưng (wazuh_metrics). Dataset cho phép áp dụng 3 mô hình học máy (Random Forest, XGBoost, CatBoost) nhằm nâng cao năng lực phân loại hành vi tấn công.

Kết quả mô hình Machine Learning khả quan.

- Random Forest cho hiệu năng ổn định, thích hợp làm baseline.
- XGBoost đạt Recall cao, giảm bỏ sót các sự kiện nguy hiểm.
- CatBoost có Precision vượt trội, giảm lỗi cảnh báo sai — rất quan trọng trong SIEM thực tế.

Sau quá trình nghiên cứu và thực nghiệm triển khai hệ thống SIEM dựa trên Wazuh kết hợp với bộ công cụ ELK trong môi trường mô phỏng gồm nhiều máy ảo, đề tài đã đạt được các mục tiêu đặt ra và chứng minh tính khả thi của mô hình phát hiện tấn công. Các kết quả thu được thể hiện rằng hệ thống có khả năng giám sát liên tục, thu thập log theo thời gian thực, phân tích và cảnh báo hiệu quả đối với nhiều hình thức tấn công an ninh mạng phổ biến.

Trước hết, quá trình cài đặt và cấu hình Wazuh Manager, Wazuh Agent, Suricata IDS, Nginx Web Server và Elasticsearch – Kibana đã được thực hiện thành công, tạo thành một pipeline ingest log hoàn chỉnh dưới kiến trúc Direct Ingest. Việc loại bỏ Logstash giúp giảm độ trễ, đồng thời vẫn đảm bảo tính ổn định và khả năng mở rộng của hệ thống. Qua các kịch bản tấn công mô phỏng như SSH brute-force, thay đổi tệp (FIM), SQL Injection, Cross-Site Scripting (XSS) và Local File Inclusion (LFI), hệ thống đã ghi nhận, phân tích và hiển thị đầy đủ các cảnh báo phù hợp trên cả Wazuh Dashboard và Kibana.

Kết quả thực nghiệm cho thấy độ trễ (latency) của pipeline nằm trong mức rất tốt, dao động từ 5–10 giây cho sự kiện FIM và sự kiện đăng nhập bất thường. Điều này khẳng định rằng mô hình SIEM được xây dựng đáp ứng yêu cầu giám sát thời gian thực. Bên cạnh đó, Watcher của Elasticsearch đã được cấu hình để gửi email cảnh báo tự động dựa trên các rule trọng yếu, tạo nên một dạng SOAR mini góp phần nâng cao khả năng phản ứng của hệ thống.

Ở giai đoạn tinh chỉnh (tuning), việc điều chỉnh rule của Wazuh, signatures của Suricata và whitelist đã giúp giảm đáng kể số lượng cảnh báo giả, đồng thời tăng độ nhạy trong phát hiện các hành vi tấn công thực tế. Dữ liệu log sau tuning cũng được sử dụng để xây dựng dataset phục vụ huấn luyện mô hình AI/ML. Ba thuật toán Random Forest, XGBoost và CatBoost đã được áp dụng để phân loại sự kiện an ninh. Kết quả cho thấy CatBoost có độ chính xác cao nhất, XGBoost có khả năng phát hiện tốt nhất (recall cao), trong khi Random Forest mang lại hiệu năng ổn định, thích hợp dùng làm baseline.

Tổng thể, đề tài đã chứng minh được hiệu quả của việc kết hợp SIEM truyền thống với các kỹ thuật học máy (Machine Learning), mở ra hướng phát triển hệ thống phát hiện tấn công chủ động, chính xác và liên tục. Hạ tầng thử nghiệm, kết quả dashboard và mô hình AI đã hoàn thiện đúng các yêu cầu của đề tài và có thể mở rộng triển khai thực tế trong doanh nghiệp quy mô nhỏ đến trung bình.

CHƯƠNG 5: KẾT LUẬN, HẠN CHẾ, HƯỚNG PHÁT TRIỂN TRONG TƯƠNG LAI

5.1. Kết luận

Sau quá trình nghiên cứu và thực nghiệm triển khai hệ thống SIEM dựa trên Wazuh kết hợp với bộ công cụ ELK (Elasticsearch, Kibana) trong môi trường mô phỏng (Lab) gồm nhiều máy ảo, đề tài đã đạt được các mục tiêu đặt ra và chứng minh tính khả thi của mô hình phát hiện tấn công. Hệ thống đã được xây dựng thành công theo kiến trúc Direct Ingest (thu thập trực tiếp), giúp tối ưu hóa tài nguyên phần cứng,.

Các kết quả chính thu được bao gồm:

- Hạ tầng và Pipeline Log Hoàn Chính: Quá trình cài đặt và cấu hình Wazuh Manager, Wazuh Agent, Suricata IDS, Nginx Web Server, cùng với Elasticsearch – Kibana đã được thực hiện thành công. Việc triển khai kiến trúc Direct Ingest (sử dụng Filebeat đẩy log trực tiếp) đã tạo thành một pipeline ingest log ổn định, loại bỏ Logstash giúp giảm độ trễ.
- Khả năng Phát hiện Đa Lớp (Multi-Layer Detection): Hệ thống đã giám sát và cảnh báo hiệu quả đối với 05 kịch bản tấn công an ninh mạng phổ biến.
 - Host-based: Wazuh phát hiện tốt các hành vi liên quan đến xác thực (SSH brute-force) và giám sát tính toàn vẹn tệp tin (FIM).
 - Network-based: Suricata nhận diện chính xác các tấn công lớp Web như SQL Injection (SQLi), Cross-Site Scripting (XSS), và Local File Inclusion (LFI).
- Độ Trễ Thấp (Low Latency): Kết quả thực nghiệm cho thấy độ trễ (Latency) của pipeline log nằm trong mức rất tốt, dao động từ 5–10 giây cho sự kiện FIM và sự kiện đăng nhập bất thường, đáp ứng yêu cầu giám sát thời gian thực,. Mục tiêu đề ra là $\text{Latency} \leq 10\text{s}$ ($\text{FIM} \leq 5\text{s}$) đã được đáp ứng.
- Tích hợp Nâng cao (SOAR mini và AI/ML):
 - Cơ chế Watcher của Elasticsearch đã được cấu hình để gửi email cảnh báo tự động dựa trên các rule trọng yếu, tạo nên một dạng SOAR mini góp phần nâng cao khả năng phản ứng của hệ thống.
 - Việc áp dụng ba mô hình học máy (Random Forest, XGBoost, CatBoost) vào phân loại sự kiện an ninh đã chứng minh hiệu quả, với CatBoost đạt Precision vượt trội (giảm cảnh báo sai) và XGBoost đạt Recall cao (giảm bỏ sót tấn công).

Tổng thể, đề tài đã chứng minh được hiệu quả của việc kết hợp SIEM truyền thống với các kỹ thuật học máy, mở ra hướng phát triển hệ thống phát hiện tấn công chủ động, chính xác và liên tục.

5.2. Hạn chế

Mặc dù đã nỗ lực hoàn thành đề tài, nhưng do giới hạn về thời gian và kinh nghiệm thực tế trong lĩnh vực an ninh mạng phức tạp, đề án vẫn còn một số thiếu sót cần được khắc phục:

- Yêu cầu Tài nguyên Phần cứng: Mặc dù đã tối ưu hóa bằng kiến trúc Direct Ingest, thành phần Elasticsearch vẫn yêu cầu lượng RAM tương đối lớn để duy trì hiệu năng đánh chỉ mục và tìm kiếm nhanh, đặc biệt khi triển khai trên môi trường ảo hóa với cấu hình hạn chế.

- Độ Phức tạp trong Tinh chỉnh (Tuning): Việc thiết lập các ngưỡng cảnh báo (threshold) để cân bằng các chỉ số hiệu quả (Precision, Recall, F1) và giảm thiểu tỷ lệ cảnh báo sai (FPR) đòi hỏi nhiều thời gian kiểm thử và kinh nghiệm vận hành thực tế.
- Thách thức trong Cấu hình Bảo mật: Việc cấu hình kết nối bảo mật (SSL/TLS) trực tiếp giữa Filebeat và Elasticsearch phức tạp hơn so với mô hình qua Logstash truyền thống, dễ phát sinh lỗi xác thực chứng chỉ trong quá trình triển khai ban đầu.
- Mô hình SOAR Cơ bản: Watcher chỉ cung cấp chức năng gửi email cảnh báo (SOAR mini), chưa phải là một nền tảng SOAR (Security Orchestration, Automation, and Response) hoàn chỉnh để tự động hóa các quy trình ứng phó phức tạp.
- Mô hình AI/ML Offline: Dataset hiện tại phục vụ huấn luyện mô hình offline, chưa được triển khai thành pipeline ML real-time để phân loại sự kiện ngay khi log được sinh ra.

5.3. Kiến nghị và hướng phát triển trong tương lai

Dựa trên kết quả thực nghiệm và các hạn chế tồn tại, nhóm đề tài đề xuất một số hướng phát triển và cải tiến nhằm nâng cao năng lực của hệ thống SIEM đã xây dựng:

- **Mở rộng Cài đặt sang Môi trường Phân tán (Cluster mode):** Elasticsearch và Wazuh Manager nên được triển khai dạng cụm (cluster) để nâng cao **khả năng chịu lỗi**, tăng tốc độ xử lý log và đáp ứng yêu cầu thu thập dữ liệu lớn hơn trong môi trường doanh nghiệp.
- **Tích hợp Nền tảng SOAR Đầy đủ:** Thay vì chỉ sử dụng Watcher cơ bản, hệ thống có thể nâng cấp lên các nền tảng SOAR chuyên nghiệp như Shuffle, Cortex, hoặc tận dụng triệt để cơ chế **Wazuh Active Response** để tự động phản ứng với các sự kiện nghiêm trọng (ví dụ: tự động khóa tài khoản khi burst 4625 xảy ra, hoặc tự động block IP khi phát hiện SSH brute-force vượt ngưỡng),..
- **Ứng dụng AI/ML theo Thời gian thực:** Triển khai một pipeline Machine Learning real-time để phân loại sự kiện ngay khi log được ingest, kết hợp với Dashboard trực quan hóa kết quả dự đoán nhằm đưa ra phản ứng tức thì.
- **Tăng cường Thử nghiệm Tấn công Nâng cao:** Ngoài các tấn công cơ bản đã mô phỏng, đề tài có thể mở rộng thử nghiệm thêm các kỹ thuật như DoS, Port Scan nâng cao, Command Injection hoặc Privilege Escalation để đánh giá toàn diện hơn khả năng bảo vệ của hệ thống.
- **Xây dựng Cơ chế Cảnh báo Đa kênh:** Ngoài email, hệ thống có thể tích hợp cảnh báo qua các kênh giao tiếp khác như Telegram, Slack, hoặc SMS để tăng tốc độ phản ứng của quản trị viên.
- **Triển khai Hệ thống trong Môi trường Thực tế Doanh nghiệp:** Mô hình hiện tại đã sẵn sàng để áp dụng trong hệ thống nội bộ doanh nghiệp nhỏ – vừa. Việc triển khai thử nghiệm thực tế sẽ giúp đánh giá thêm các yếu tố về hiệu năng, tối ưu cấu hình và mức độ phù hợp với nhu cầu vận hành

TÀI LIỆU THAM KHẢO

Wazuh – Hướng dẫn cài đặt (Manager/Agent/Dashboard:

<https://documentation.wazuh.com/current/installation-guide/index.html>

Cài Kibana (Elastic Docs): <https://www.elastic.co/docs/deploy-manage/deploy/self-managed/install-kibana>

Cài Elasticsearch (Elastic Docs: <https://www.elastic.co/docs/deploy-manage/deploy/self-managed/installing-elasticsearch>

Filebeat – cài đặt & cấu hình

nhanh: <https://www.elastic.co/docs/reference/beats/filebeat/filebeat-installation-configuration>

Winlogbeat – cài đặt & chạy trên

Windows: <https://www.elastic.co/docs/reference/beats/winlogbeat/winlogbeat-installation-configuration>

Suricata – User Guide: <https://docs.suricata.io/en/suricata-8.0.1/>

Zeek – Installing (Book of Zeek): <https://docs.suricata.io/en/suricata-8.0.1/>

MITRE ATT&CK: <https://attack.mitre.org/>